

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ
TRUYỀN THÔNG VIỆT HÀN
KHOA KỸ THUẬT MÁY TÍNH VÀ ĐIỆN TỬ**



**ĐỒ ÁN CHUYÊN NGÀNH 3
NGHIÊN CỨU VÀ XÂY DỰNG CÔNG CỤ ĐÁNH GIÁ
BẢO MẬT MẠNG WI-FI**

Họ và tên sinh viên	: NGUYỄN ĐỨC HUY
Lớp	: 22NS
Ngành	: Mạng và An toàn thông tin
Giảng viên hướng dẫn	: TS. ĐẶNG QUANG HIỂN KS. LÊ THỊ KHÁNH DUNG

Đà Nẵng, ngày 12 tháng 5 năm 2026

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ
TRUYỀN THÔNG VIỆT HÀN
KHOA KỸ THUẬT MÁY TÍNH VÀ ĐIỆN TỬ**



**ĐỒ ÁN CHUYÊN NGÀNH 3
NGHIÊN CỨU VÀ XÂY DỰNG CÔNG CỤ ĐÁNH GIÁ
BẢO MẬT MẠNG WI-FI**

Họ và tên sinh viên	: NGUYỄN ĐỨC HUY
Lớp	: 22NS
Ngành	: Mạng và An toàn thông tin
Giảng viên hướng dẫn	: TS. ĐẶNG QUANG HIỂN KS. LÊ THỊ KHÁNH DUNG

Đà Nẵng, ngày 12 tháng 5 năm 2026

LỜI CẢM ƠN

Lời đầu tiên, em xin chân thành cảm ơn Ban Giám hiệu cùng các thầy, cô giáo khoa Kỹ thuật máy tính và Điện tử trường Đại học Công nghệ thông tin và truyền thông Việt Hàn đã truyền đạt cho em những kiến thức nền tảng quý báu và tạo điều kiện thuận lợi cho em trong suốt quá trình học tập tại trường.

Em xin bày tỏ lòng biết ơn sâu sắc đến thầy TS. Đặng Quang Hiên, người đã trực tiếp hướng dẫn, định hướng khoa học và đưa ra những nhận xét, chỉ dẫn chuyên môn quý báu trong suốt quá trình em thực hiện đề tài "Nghiên cứu và xây dựng công cụ đánh giá bảo mật mạng Wi-Fi". Những định hướng đúng đắn của thầy là yếu tố quan trọng giúp đề tài đi đúng hướng và hoàn thiện về mặt lý luận cũng như thực tiễn.

Em cũng xin gửi lời cảm ơn chân thành đến chị KS. Lê Thị Khánh Dung đã luôn đồng hành, nhiệt tình hỗ trợ về mặt kỹ thuật, chia sẻ những kinh nghiệm thực tiễn và giúp đỡ em giải quyết các khó khăn trong quá trình triển khai, xây dựng công cụ.

Mặc dù đã có nhiều cố gắng để hoàn thành đề tài, song do giới hạn về kiến thức và kinh nghiệm thực tiễn, báo cáo khó tránh khỏi những thiếu sót. Em rất mong nhận được những ý kiến đóng góp, nhận xét của thầy cô và các chuyên gia để đề tài được hoàn thiện hơn.

Em xin kính chúc thầy TS. Đặng Quang Hiên, chị KS. Lê Thị Khánh Dung cùng quý thầy cô giáo luôn mạnh khỏe, hạnh phúc và gặt hái được nhiều thành công trong công tác giảng dạy cũng như sự nghiệp.

Em xin chân thành cảm ơn!

Đà Nẵng, ngày 12 tháng 5 năm 2026

Sinh viên thực hiện



Nguyễn Đức Huy

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

This image shows a full page of white paper with horizontal ruling lines. The lines are evenly spaced and extend across the width of the page. There are no margins, text, or other markings on the paper.

Đà Nẵng, ngày ... tháng 5 năm 2026

Giảng viên hướng dẫn

TS. ĐẶNG QUANG HIỂN KS. LÊ THỊ KHÁNH DUNG

MỤC LỤC

LỜI CẢM ƠN	i
NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN	ii
MỤC LỤC	iii
DANH MỤC HÌNH ẢNH	v
DANH MỤC BẢNG	vi
DANH MỤC TỪ VIẾT TẮT	vii
MỞ ĐẦU	1
CHƯƠNG 1. CƠ SỞ LÝ THUYẾT	3
1.1. Tổng quan về công nghệ mạng không dây (Wi-Fi)	3
1.1.1. Khái niệm và chuẩn kết nối IEEE 802.11	3
1.1.2. Kiến trúc mạng Wi-Fi và các thành phần cơ bản	4
1.1.3. Quá trình kết nối và trao đổi dữ liệu trong mạng Wi-Fi	5
1.2. Các giao thức bảo mật mạng Wi-Fi	7
1.2.1. Giao thức WEP (Wired Equivalent Privacy)	7
1.2.2. Giao thức WPA/WPA2 (Wi-Fi Protected Access) và cơ chế bắt tay 4 bước (4-way handshake)	9
1.2.3. Giao thức WPA3 và cơ chế SAE (Simultaneous Authentication of Equals)	10
1.2.4. Cơ chế WPS (Wi-Fi Protected Setup)	12
1.3. Các phương thức tấn công và lỗ hổng bảo mật Wi-Fi phổ biến	13
1.3.1. Tấn công từ chối dịch vụ (Deauthentication/Disassociation Attack)	13
1.3.2. Tấn công thu thập Handshake và bể khóa mật khẩu (Offline Dictionary Attack)	14
1.3.3. Tấn công giả mạo điểm truy cập (Evil Twin / Rogue AP)	14
1.3.4. Khai thác lỗ hổng WPS (Pixie Dust, PIN brute-force)	15
CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG	17
2.1. Phân tích yêu cầu hệ thống	17
2.1.1. Yêu cầu chức năng	17
2.1.2. Yêu cầu phi chức năng	17
2.2. Thiết kế kiến trúc phần mềm	17
2.2.1. Kiến trúc tổng thể	17
2.2.2. Thiết kế cơ chế đa luồng cho các tác vụ mạng	18
2.3. Mô hình hóa hệ thống	19
2.3.1. Biểu đồ Use Case	19
2.3.2. Biểu đồ Hoạt động (Activity Diagram) – Luồng quét và thu thập thông số AP	19
2.3.3. Biểu đồ Hoạt động (Activity Diagram) – Luồng mô phỏng tấn công (Deauth -> Capture -> Crack)	20
2.3.4. Biểu đồ Tuần tự (Sequence Diagram) – Quá trình xuất báo cáo đánh giá bảo mật (PDF)	20
2.4. Thiết kế thuật toán và động cơ xử lý	21

2.4.1. Thuật toán phân tích và chấm điểm rủi ro bảo mật	21
2.4.2. Cơ chế giám sát và bắt gói tin Handshake tự động	21
CHƯƠNG 3. TRIỂN KHAI ĐỀ TÀI	23
3.1. Môi trường phát triển và cấu hình triển khai	23
3.1.1. Yêu cầu phần cứng và card mạng	23
3.1.2. Môi trường phần mềm	23
3.2. Triển khai các phân hệ chức năng chính	23
3.2.1. Phân hệ Bảng điều khiển giám sát tổng quan (Dashboard Page)	23
3.2.2. Phân hệ Quét và trích xuất thông tin Access Point (Scan Page)	25
3.2.3. Phân hệ Đánh giá bảo mật và đề xuất giải pháp (Analyze Page)	26
3.2.4. Phân hệ Mô phỏng tấn công kiểm thử (Attack Page - Deauth & Crack)	28
3.2.5. Phân hệ Tổng hợp và trích xuất báo cáo (PDF Report Generator)	32
3.3. Đánh giá kết quả đạt được	33
3.3.1. Ưu điểm của giải pháp	33
3.3.2. Các mặt hạn chế còn tồn đọng	34
KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	35
TÀI LIỆU THAM KHẢO	36

DANH MỤC HÌNH ẢNH

Hình 1.1 . Mô hình kiến trúc Extended Service Set (ESS)	5
Hình 1.2 . Tiến trình thiết lập kết nối	6
Hình 1.3 . Cơ chế mã hóa của WEP	8
Hình 1.4 . Cơ chế bắt tay 4 bước (4-way Handshake)	10
Hình 1.5 . Cơ chế xác thực SAE	11
Hình 1.6 . Quy trình triển khai kiểm thử WPS	16
Hình 2.1 . Biểu đồ User case	19
Hình 2.2 . Biểu đồ Hoạt động luồng quét và thu thập thông số AP	19
Hình 2.3 . Biểu đồ Hoạt động luồng mô phỏng tấn công	20
Hình 2.4 . Biểu đồ Tuần tự quá trình xuất báo cáo đánh giá bảo mật	20
Hình 3.1 . Giao diện Dashboard trước khi quét	23
Hình 3.2 . Giao diện chọn interface	24
Hình 3.3 . Giao diện Dashboard sau khi quét	24
Hình 3.4 . Giao diện Scan	25
Hình 3.5 . Các tùy chọn cho wifi	26
Hình 3.6 . Chọn tính năng phân tích	26
Hình 3.7 . Giao diện Analyze	26
Hình 3.8 . Điểm đánh giá bảo mật	27
Hình 3.9 . Các giải pháp gợi ý cho các cấu hình yếu	27
Hình 3.10 . Chọn wifi để kiểm thử độ mạnh mật khẩu	28
Hình 3.11 . Giao diện Attack	28
Hình 3.12 . Nút chuyển đổi sang chế độ Monitor	28
Hình 3.13 . Chế độ thu thập gói tin	29
Hình 3.14 . Chế độ gửi gói tin Deauthentication	30
Hình 3.15 . Bắt gói tin Handshake thành công	30
Hình 3.16 . Chọn wordlist cho quá trình kiểm thử	30
Hình 3.17 . Bắt đầu chạy kiểm thử	31
Hình 3.18 . Trường hợp không tìm thấy mật khẩu	31
Hình 3.19 . Trường hợp tìm thấy mật khẩu	31
Hình 3.20 . Kết quả quá trình kiểm thử	32
Hình 3.21 . Giao diện xuất báo cáo file PDF	32
Hình 3.22 . Thông báo xuất file thành công	32
Hình 3.23 . Kết quả file báo cáo	33

DANH MỤC BẢNG

Bảng 1.1 . Bảng tổng hợp các chuẩn kết nối IEEE 802.11	4
Bảng 1.2 . So sánh hai loại khung hình bị lợi dụng	13
Bảng 1.3 . Thu thập Handshake trực tuyến	14
Bảng 1.4 . Định nghĩa Evil Twin và Rogue AP	15
Bảng 1.5 . So sánh hai phương thức khai thác WPS	16

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ gốc
AID	Association Identifier
ANonce	Authenticator Nonce
BSSID	Basic Service Set Identifier
CCK	Complementary Code Keying
CCMP	Counter Mode Cipher Block Chaining Message Authentication Code Protocol
CSMA/CA	Carrier Sense Multiple Access with Collision Avoidance
EAPOL	Extensible Authentication Protocol over LAN
ESS	Extended Service Set
FMS	Fluhrer, Mantin, and Shamir
GTK	Group Temporal Key
IBSS	Independent Basic Service Set
ICV	Integrity Check Value
KCK	Key Confirmation Key
MFP / PMF	Management Frame Protection / Protected Management Frames
MLO	Multi-Link Operation
NAV	Network Allocation Vector
OFDMA	Orthogonal Frequency Division Multiple Access
OSA	Open System Authentication
OWE	Opportunistic Wireless Encryption
PBC	Push Button Configuration
PBKDF2	Password-Based Key Derivation Function 2
PMK	Pairwise Master Key
PTK	Pairwise Transient Key
PTW	Pyshkin, Tews, and Weinmann
PWE	Password-Derived Element
SNonce	Supplicant Nonce
SAE	Simultaneous Authentication of Equals
TKIP	Temporal Key Integrity Protocol
WIDS / WIPS	Wireless Intrusion Detection/Prevention System

MỞ ĐẦU

1. Lý do chọn đề tài

Mạng Wi-Fi hiện nay là hạ tầng kết nối không thể thiếu, nhưng do đặc thù truyền dẫn qua sóng vô tuyến trong không gian mở, hệ thống này luôn đối mặt với nhiều nguy cơ mất an toàn thông tin hơn mạng dây truyền thống. Thực tế cho thấy, nhiều mạng Wi-Fi vẫn tồn tại các lỗ hổng nghiêm trọng do cấu hình sai sót, mật khẩu yếu hoặc sử dụng các giao thức cũ kém an toàn (như WPS).

Để phòng ngừa rủi ro, việc đánh giá bảo mật định kỳ là rất cần thiết. Tuy nhiên, các công cụ kiểm thử hiện có thường phức tạp, chủ yếu vận hành qua dòng lệnh và đòi hỏi người dùng phải có kiến thức chuyên môn sâu. Xuất phát từ nhu cầu đó, đề tài “Nghiên cứu và xây dựng công cụ đánh giá bảo mật mạng Wi-Fi” được thực hiện nhằm phát triển một giải pháp trực quan, tự động hóa quy trình rà quét và kiểm thử, giúp người quản trị dễ dàng đánh giá, phát hiện lỗ hổng và chủ động nâng cao tính an toàn cho hệ thống mạng nội bộ.

2. Mục tiêu nghiên cứu

- **Về lý thuyết:** Nghiên cứu chuẩn bảo mật IEEE 802.11 (WEP, WPA/WPA2/WPA3, MFP) và nguyên lý của các kỹ thuật khai thác lỗ hổng mạng Wi-Fi.
- **Về thực tiễn (Xây dựng công cụ):**
 - + Xây dựng công cụ có giao diện đồ họa (GUI) trực quan, hỗ trợ rà quét và hiển thị thông số các trạm phát sóng (AP) theo thời gian thực.
 - + Tự động hóa quy trình kiểm thử xâm nhập khép kín: Gửi gói tin ngắt kết nối (Deauth) -> Bắt gói tin bắt tay (Handshake) -> Dò mật khẩu ngoại tuyến (Offline cracking) bằng từ điển.
 - + Tích hợp công cụ chấm điểm rủi ro và tự động xuất báo cáo đánh giá định dạng PDF kèm giải pháp khắc phục.

3. Đối tượng và phạm vi nghiên cứu

- **Đối tượng nghiên cứu:**
 - + Các giao thức bảo mật Wi-Fi, thuật toán mã hóa (AES/CCMP, TKIP) và cơ chế bảo vệ khung quản lý MFP.
 - + Kỹ thuật tấn công Deauth và bẻ khóa mã băm mật khẩu ngoại tuyến.
 - + Thư viện lập trình giao diện đồ họa, xử lý đa luồng (Multi-threading) và tương tác mạng cấp thấp.
- **Phạm vi nghiên cứu:**
 - + Rà quét các AP trong tầm thu nhận tín hiệu của phần cứng máy tính.
 - + Giới hạn kiểm thử xâm nhập thực tế đối với cơ chế xác thực cá nhân (WPA/WPA2-PSK) bằng phương pháp tấn công từ điển.
 - + Công cụ vận hành trên hệ điều hành Linux, yêu cầu card mạng Wi-Fi hỗ trợ chế độ Monitor Mode và Packet Injection.

4. Phương pháp nghiên cứu

- **Phương pháp lý thuyết:** Nghiên cứu tài liệu chuẩn IEEE 802.11, cấu trúc gói tin và các lỗ hổng giao thức đã công bố.

- **Phương pháp thực hành và lập trình:** Sử dụng ngôn ngữ Python kết hợp lập trình đa luồng để xây dựng giao diện GUI không bị đóng băng khi chạy tác vụ ngầm. Phát triển công cụ theo cấu trúc module hóa (quét, tấn công, xuất báo cáo).
- **Phương pháp thực nghiệm:** Thiết lập hệ thống kiểm thử (Lab) thực tế gồm Router mục tiêu, thiết bị khách và máy kiểm thử để đo lường, đánh giá tính ổn định và độ chính xác của công cụ.

5. Ý nghĩa khoa học và thực tiễn của đề tài

- **Ý nghĩa khoa học:** Đề tài góp phần hệ thống hóa các kiến thức nền tảng về an toàn thông tin mạng không dây, làm rõ cơ chế hoạt động của các lỗ hổng bảo mật trên giao thức Wi-Fi phổ biến. Kết quả nghiên cứu có thể làm tài liệu tham khảo cho các nghiên cứu tiếp theo về an ninh mạng không dây.
- **Ý nghĩa thực tiễn:**
 - + Cung cấp một công cụ hỗ trợ cho các quản trị viên mạng hoặc người dùng cá nhân trong việc tự kiểm tra, phát hiện nhanh các cấu hình thiếu an toàn của mạng Wi-Fi nội bộ.
 - + Giúp người dùng nâng cao nhận thức về nguy cơ mất an toàn thông tin trên mạng không dây, từ đó chủ động áp dụng các biện pháp phòng ngừa và nâng cấp cấu hình bảo mật phù hợp nhằm bảo vệ dữ liệu cá nhân cũng như tổ chức.

6. Bố cục báo cáo

MỞ ĐẦU

CHƯƠNG 1: CƠ SỞ LÝ THUYẾT

CHƯƠNG 2: PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

CHƯƠNG 3: TRIỂN KHAI ĐỀ TÀI

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

TÀI LIỆU THAM KHẢO

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.1. Tổng quan về công nghệ mạng không dây (Wi-Fi)

1.1.1. Khái niệm và chuẩn kết nối IEEE 802.11

a) Khái niệm về công nghệ Wi-Fi

Wi-Fi (viết tắt của Wireless Fidelity) là thuật ngữ thương mại đại diện cho hệ thống mạng không dây địa phương (WLAN - Wireless Local Area Network) hoạt động dựa trên bộ tiêu chuẩn IEEE 802.11. Công nghệ này cho phép các thiết bị điện tử như máy tính, điện thoại thông minh, máy tính bảng và các thiết bị IoT (Internet of Things) kết nối và trao đổi dữ liệu với nhau hoặc truy cập mạng Internet thông qua sóng vô tuyến (Radio Frequency - RF) mà không cần sử dụng hệ thống cáp vật lý truyền thống.

Về nguyên lý hoạt động vật lý, mạng Wi-Fi sử dụng sóng điện từ thuộc các dải băng tần không cấp phép (ISM - Industrial, Scientific, and Medical) để truyền tải thông tin. Khác với mạng có dây truyền thống sử dụng dây cáp đồng hoặc cáp quang làm môi trường truyền dẫn khép kín, Wi-Fi sử dụng không gian tự do làm môi trường truyền dẫn. Đặc tính này mang lại sự tiện lợi, linh hoạt trong triển khai nhưng đồng thời cũng tự tạo ra những thách thức lớn về mặt an ninh thông tin. Do tín hiệu sóng vô tuyến lan tỏa tự do trong không gian theo mọi hướng và không có ranh giới vật lý cố định, bất kỳ thiết bị nào nằm trong vùng phủ sóng có card mạng phù hợp đều có thể thu thập, chặn thu hoặc can thiệp vào luồng dữ liệu nếu không có các biện pháp bảo mật và mã hóa phù hợp.

b) Tiến trình phát triển các chuẩn kết nối IEEE 802.11

- Từ năm 1997, tiêu chuẩn IEEE 802.11 đã trải qua nhiều thế hệ nâng cấp nhằm tối ưu hóa tốc độ, băng tần và hiệu suất truyền tải:
- IEEE 802.11 Legacy (1997): Băng tần 2.4 GHz, tốc độ tối đa 2 Mbps. Sử dụng kỹ thuật FHSS/DSSS; nhanh chóng lỗi thời do tốc độ thấp và dễ nhiễu.
- IEEE 802.11b (1999): Băng tần 2.4 GHz, tốc độ tối đa 11 Mbps nhờ kỹ thuật CCK. Chuẩn Wi-Fi đầu tiên phổ biến rộng rãi nhờ chi phí phần cứng rẻ.
- IEEE 802.11a (1999): Băng tần 5 GHz (ít nhiễu), tốc độ tối đa 54 Mbps với kỹ thuật OFDM. Phạm vi phủ sóng ngắn và dễ bị cản trở.
- IEEE 802.11g (2003): Băng tần 2.4 GHz, tốc độ tối đa 54 Mbps (OFDM). Tương thích ngược với chuẩn 802.11b, cân bằng giữa tốc độ và tầm phủ sóng.
- IEEE 802.11n (Wi-Fi 4 - 2009): Hỗ trợ song băng tần 2.4 GHz và 5 GHz, tốc độ lý thuyết lên đến 600 Mbps. Giới thiệu công nghệ đa anten MIMO giúp tăng độ ổn định.
- IEEE 802.11ac (Wi-Fi 5 - 2013): Hoạt động ở băng tần 5 GHz, tốc độ tối đa 6.9 Gbps. Mở rộng kênh truyền lên 160 MHz, dùng điều chế 256-QAM và công nghệ MU-MIMO.
- IEEE 802.11ax (Wi-Fi 6/6E - 2019): Băng tần 2.4 GHz, 5 GHz (và 6 GHz đối với 6E), tốc độ tối đa 9.6 Gbps. Tích hợp công nghệ OFDMA và 1024-QAM giúp giảm độ trễ trong môi trường mật độ cao.

- IEEE 802.11be (Wi-Fi 7 - 2024): Thế hệ mới nhất, tốc độ tối đa 46 Gbps. Sử dụng kênh truyền 320 MHz, điều chế 4096-QAM và tính năng hoạt động đa liên kết MLO (Multi-Link Operation) cho phép truyền nhận đồng thời trên nhiều băng tần.

Chuẩn kết nối	Thế hệ Wi-Fi	Băng tần hoạt động	Tốc độ lý thuyết tối đa	Kỹ thuật điều chế tiêu biểu
802.11	-	2.4 GHz	2 Mbps	DSSS, FHSS
802.11b	-	2.4 GHz	11 Mbps	DSSS, CCK
802.11a	-	5 GHz	54 Mbps	OFDM
802.11g	-	2.4 GHz	54 Mbps	OFDM
802.11n	Wi-Fi 4	2.4 GHz, 5 GHz	600 Mbps	MIMO, OFDM
802.11ac	Wi-Fi 5	5 GHz	6.9 Gbps	MU-MIMO, 256-QAM
802.11ax	Wi-Fi 6 / 6E	2.4 GHz, 5 GHz, 6 GHz	9.6 Gbps	OFDMA, 1024-QAM
802.11be	Wi-Fi 7	2.4 GHz, 5 GHz, 6 GHz	46 Gbps	MLO, 4096-QAM

Bảng 1.1. Bảng tổng hợp các chuẩn kết nối IEEE 802.11

1.1.2. Kiến trúc mạng Wi-Fi và các thành phần cơ bản

a) Các thành phần cơ bản trong mạng Wi-Fi

- **Thiết bị trạm (Station - STA):** Là bất kỳ thiết bị đầu cuối nào tích hợp card mạng không dây tương thích chuẩn IEEE 802.11 (như máy tính, điện thoại, thiết bị IoT). STA thực hiện chuyển đổi dữ liệu số thành tín hiệu vô tuyến và ngược lại. Trong bảo mật, STA là đối tượng trực tiếp chịu ảnh hưởng bởi tấn công ngắt kết nối (Deauth) hoặc bị lợi dụng để thu thập handshake.
- **Điểm truy cập không dây (Access Point - AP):** Là thiết bị trung tâm điều phối mạng, đóng vai trò cầu nối chuyển đổi định dạng khung dữ liệu giữa mạng không dây (802.11) và mạng có dây (802.3 Ethernet). AP quản lý quá trình xác thực (Authentication) và cấp quyền kết nối (Association) cho các STA, đồng thời là mục tiêu khảo sát chính khi đánh giá bảo mật.
- **Hệ thống phân phối (Distribution System - DS):** Là thành phần liên kết các AP lại với nhau hoặc nối AP với mạng xương sống (backbone) có dây. DS chịu trách nhiệm chuyển tiếp dữ liệu và hỗ trợ quá trình chuyển vùng (roaming) thông suốt cho các STA.
- **Môi trường không dây (Wireless Medium - WM):** Là không gian vật lý truyền tải sóng vô tuyến chứa các khung dữ liệu 802.11, hoạt động trên các dải tần số quy định (chủ yếu là 2.4 GHz, 5 GHz và 6 GHz).

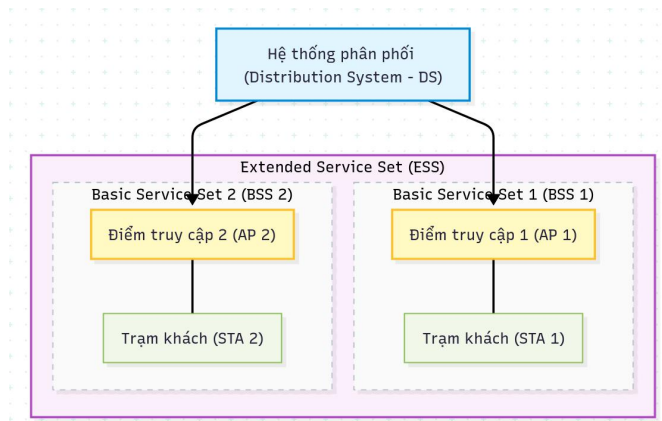
b) Các mô hình kiến trúc mạng (Service Sets)

IEEE 802.11 định nghĩa ba mô hình cấu trúc mạng không dây cơ bản, hay còn gọi là các Tập hợp dịch vụ (Service Sets):

- **IBSS (Independent Basic Service Set / Ad-hoc):** Mô hình mạng ngang hàng (peer-to-peer), cho phép các thiết bị trạm (STA) kết nối trực tiếp với nhau không qua điểm truy cập (AP) trung tâm. Thường dùng cho kết nối tạm thời ở phạm vi

hợp. Mô hình này tiềm ẩn rủi ro bảo mật lớn do thiếu cơ chế quản lý và kiểm soát truy cập tập trung.

- **BSS (Infrastructure Basic Service Set):** Mô hình mạng có hạ tầng phổ biến nhất, gồm một AP trung tâm kết nối với các STA. Mọi dữ liệu trao đổi giữa các STA bắt buộc phải truyền trung gian qua AP. Mỗi BSS được định danh vật lý duy nhất bằng BSSID (địa chỉ MAC của giao diện không dây trên AP).
- **ESS (Extended Service Set):** Mô hình mở rộng gồm nhiều BSS liên kết với nhau qua Hệ thống phân phối (DS) để mở rộng phạm vi phủ sóng. ESS cho phép các STA di chuyển liên tục giữa các AP (Roaming) mà không bị gián đoạn kết nối. Toàn bộ AP trong ESS chia sẻ chung định danh mạng logic là SSID (tên mạng Wi-Fi hiển thị).



Hình 1.1. Mô hình kiến trúc Extended Service Set (ESS)

1.1.3. Quá trình kết nối và trao đổi dữ liệu trong mạng Wi-Fi

a) Tiến trình thiết lập kết nối (Connection Process)

Tiến trình kết nối giữa một thiết bị trạm (STA) và Điểm truy cập (AP) diễn ra qua ba giai đoạn tuần tự sau:

Bước 1: Quét nhận biết mạng (Active/Passive Scan): STA thực hiện tìm kiếm và nhận biết các AP xung quanh thông qua một trong hai cơ chế:

- Passive Scan (Quét bị động): STA lắng nghe khung quảng bá Beacon phát ra từ AP định kỳ (thường là 100ms/lần).
- Active Scan (Quét chủ động): STA chủ động phát khung Probe Request trên các kênh tần số và đợi các AP phản hồi bằng khung Probe Response.

Bước 2 & 3: Xác thực hệ thống (802.11 Authentication Request & Response): Đây là bước xác thực cơ bản ở tầng liên kết dữ liệu của chuẩn 802.11 sơ khai, chưa phải là bước xác thực mật khẩu WPA.

(2) Authentication Req: STA gửi yêu cầu xác thực hệ thống đến AP.

(3) Authentication Resp: AP xử lý và phản hồi. Trong hầu hết các mạng Wi-Fi hiện đại sử dụng cơ chế Xác thực hệ thống mở (Open System Authentication - OSA), AP sẽ chấp nhận yêu cầu của STA mà không đòi hỏi kiểm tra thông tin danh tính tại bước này.

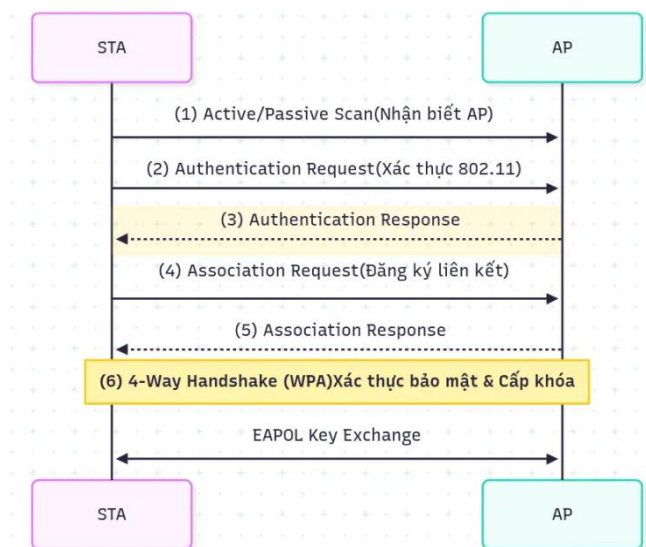
Bước 4 & 5: Thiết lập liên kết (Association Request & Response): Sau khi hoàn thành xác thực cơ bản, hai thiết bị tiến hành đăng ký liên kết logic để STA chính thức gia nhập vào mạng BSS:

(4) Association Req: STA gửi yêu cầu đăng ký liên kết, chứa các thông số về khả năng truyền dẫn và các chuẩn mã hóa mà STA hỗ trợ.

(5) Association Resp: AP xem xét các tham số, nếu tương thích sẽ cấp phát một Định danh liên kết (Association ID - AID) và phản hồi chấp nhận cho STA.

Bước 6: Quá trình bắt tay 4 bước (4-Way Handshake - WPA/WPA2): Sau khi liên kết logic được thiết lập thành công, nếu mạng Wi-Fi cấu hình các giao thức bảo mật (như WPA/WPA2-PSK), AP và STA bắt buộc phải thực hiện quá trình bắt tay 4 bước:

- Quá trình này sử dụng Khóa tiền chia sẻ (Pre-Shared Key - PSK) làm cơ sở để xác thực tính hợp lệ của mật khẩu mà STA nhập vào mà không cần truyền mật khẩu trực tiếp qua không gian.
- Mục tiêu của bước này là xác thực lẫn nhau giữa STA và AP, đồng thời thỏa thuận và tạo ra các khóa mã hóa động bao gồm Khóa tạm thời đơn nhất (Pairwise Transient Key - PTK) dùng để mã hóa dữ liệu Unicast và Khóa tạm thời nhóm (Group Temporal Key - GTK) dùng cho dữ liệu Multicast/Broadcast.
- Chỉ khi hoàn thành thành công bước bắt tay 4 bước này, kênh truyền dữ liệu mới được mã hóa và STA mới chính thức có quyền truy cập Internet hoặc mạng nội bộ.



Hình 1.2. Tiến trình thiết lập kết nối

b) Cơ chế kiểm soát truy cập môi trường truyền dẫn (CSMA/CA)

Khác với mạng có dây sử dụng cáp truyền dẫn riêng biệt và cơ chế phát hiện xung đột CSMA/CD, môi trường truyền dẫn không dây là sóng vô tuyến chia sẻ (Shared Medium) hoạt động ở chế độ bán song công (Half-duplex) - nghĩa là tại một thời điểm, trên một kênh tần số, chỉ có một thiết bị được phép truyền dữ liệu.

Để tránh hiện tượng chồng lấn tín hiệu gây mất mát dữ liệu, chuẩn 802.11 sử dụng cơ chế CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance - Đa truy cập cảm nhận sóng mang tránh xung đột):

- Cảm nhận kênh truyền (Carrier Sensing): Trước khi truyền, thiết bị sẽ lắng nghe kênh truyền (qua cả phần cứng vật lý và thời gian logic NAV - Network Allocation Vector). Nếu kênh bận, thiết bị sẽ chờ.
- Thời gian chờ ngẫu nhiên (Backoff Timer): Khi kênh truyền rảnh, thiết bị không truyền ngay lập tức mà chọn một khoảng thời gian chờ ngẫu nhiên từ cửa sổ tranh chấp (Contention Window). Thiết bị chỉ truyền khi bộ đếm này giảm về 0 mà kênh vẫn rảnh.
- Xác nhận truyền thành công (ACK): Do không thể vừa truyền vừa phát hiện xung đột trực tiếp trên sóng vô tuyến, thiết bị nhận sau khi nhận dữ liệu nguyên vẹn bắt buộc phải gửi lại một khung xác nhận ACK (Acknowledgment) cho thiết bị truyền. Nếu thiết bị truyền không nhận được khung ACK sau một khoảng thời gian quy định, nó coi như đã xảy ra xung đột và tiến hành truyền lại gói tin.

c) Các nhóm khung hình (Frame Types) trong chuẩn 802.11

Mọi luồng dữ liệu truyền qua không gian đều được đóng gói thành các khung hình 802.11 thuộc ba nhóm chính:

- Khung quản lý (Management Frames): Sử dụng để thiết lập và duy trì kết nối logic (bao gồm Beacon, Probe, Association, Authentication, Deauthentication, Disassociation). Điểm yếu của các khung này trong chuẩn cũ là không được mã hóa, tạo điều kiện cho các cuộc tấn công ngắt kết nối giả mạo (Deauthentication Attack).
- Khung kiểm soát (Control Frames): Hỗ trợ quá trình phân phối dữ liệu và kiểm soát kênh truyền (bao gồm ACK, RTS - Request to Send, CTS - Clean to Send).
- Khung dữ liệu (Data Frames): Mang thông tin payload thực tế của người dùng (như dữ liệu IP, gói tin Web, Email). Nội dung của khung dữ liệu sẽ được mã hóa nếu mạng Wi-Fi có bật chế độ bảo mật.

1.2. Các giao thức bảo mật mạng Wi-Fi

1.2.1. Giao thức WEP (Wired Equivalent Privacy)

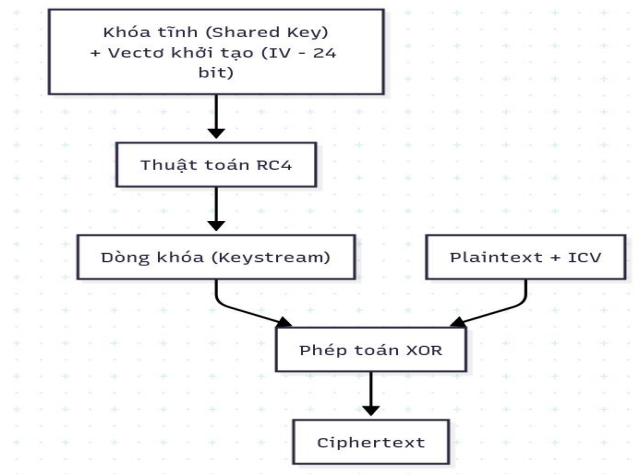
WEP (Wired Equivalent Privacy) được ra đời vào năm 1997, là giao thức bảo mật đầu tiên được tích hợp trong tiêu chuẩn gốc IEEE 802.11. Mục tiêu ban đầu của WEP là cung cấp một mức độ bảo mật thông tin và tính riêng tư cho mạng không dây tương đương với tính an toàn vật lý của mạng cục bộ có dây (LAN). Tuy nhiên, do những hạn chế trong thiết kế mật mã học, WEP đã nhanh chóng lộ ra các lỗ hổng nghiêm trọng và hiện nay đã hoàn toàn bị loại bỏ khỏi các hệ thống mạng thực tế.

a) Tổng quan về WEP

WEP (Wired Equivalent Privacy) được ra đời vào năm 1997, là giao thức bảo mật đầu tiên được tích hợp trong tiêu chuẩn gốc IEEE 802.11. Mục tiêu ban đầu của WEP là cung cấp một mức độ bảo mật thông tin và tính riêng tư cho mạng không dây tương đương với tính an toàn vật lý của mạng cục bộ có dây (LAN). Tuy nhiên, do những hạn chế trong thiết kế mật mã học, WEP đã nhanh chóng lộ ra các lỗ hổng nghiêm trọng và hiện nay đã hoàn toàn bị loại bỏ khỏi các hệ thống mạng thực tế.

b) Cơ chế mã hóa của WEP

WEP sử dụng thuật toán mã hóa đối xứng dòng RC4 (Rivest Cipher 4) để bảo vệ tính bảo mật của dữ liệu và sử dụng thuật toán kiểm tra mã dư tuần hoàn CRC-32 (Cyclic Redundancy Check) để đảm bảo tính toàn vẹn của gói tin.



Hình 1.3. Cơ chế mã hóa của WEP

Quy trình mã hóa một gói tin dưới giao thức WEP diễn ra như sau:

- Tạo giá trị kiểm tra tính toàn vẹn (ICV): Bản rõ (Plaintext) được tính toán qua thuật toán CRC-32 để tạo ra giá trị ICV (Integrity Check Value). ICV sau đó được ghép vào cuối bản rõ.
- Tạo khóa gói tin: Một Vectơ khởi tạo IV (Initialization Vector) có độ dài 24 bit được tạo ra ngẫu nhiên và kết hợp với Khóa tĩnh chia sẻ (Pre-shared Key - thường có độ dài 40 bit hoặc 104 bit) để tạo ra một khóa kết hợp dài 64 bit hoặc 128 bit.
- Sinh dòng khóa (Keystream): Khóa kết hợp này được đưa vào thuật toán RC4 để tạo ra một dòng khóa (Keystream) ngẫu nhiên có độ dài tương ứng với độ dài của chuỗi (Plaintext + ICV).
- Thực hiện phép toán XOR: Thực hiện phép toán logic XOR ($\oplus$) giữa dòng khóa và chuỗi (Plaintext + ICV) để thu được bản mã (Ciphertext).
- Đóng gói truyền đi: Giá trị IV (ở dạng bản rõ không mã hóa) được đính kèm vào phần đầu của bản mã để tạo thành khung dữ liệu hoàn chỉnh truyền đi trong không gian. Thiết bị nhận sẽ sử dụng IV này kết hợp với khóa tĩnh có sẵn để giải mã ngược lại.

c) Các lỗ hổng bảo mật nghiêm trọng của WEP

- Không gian Vectơ khởi tạo (IV) quá ngắn: Độ dài IV chỉ có 24 bit, tạo ra tối đa $2^{24} \approx 16.7$ triệu giá trị. Trên các mạng có lưu lượng lớn, hiện tượng trùng lặp IV (IV Collision) xảy ra rất nhanh, cho phép kẻ tấn công thực hiện phép toán XOR giữa các gói tin trùng IV để khôi phục dòng khóa gốc.
- Điểm yếu RC4 và Vectơ khởi tạo yếu (Weak IVs): Theo nghiên cứu FMS (Fluhrer, Mantin, Shamir), thuật toán RC4 trong WEP sinh ra các IV yếu khiến các byte đầu tiên của dòng khóa bị lộ mối liên hệ toán học với khóa tĩnh. Thu thập đủ số lượng IV yếu này cho phép suy luận ngược ra khóa gốc.
- Cơ chế kiểm tra tính toàn vẹn CRC-32 yếu: CRC-32 là hàm tuyến tính, không phải hàm băm bảo mật. Kẻ tấn công có thể thực hiện tấn công lật bit (Bit-flipping attack)

- thay đổi dữ liệu bản mã và tính toán lại giá trị ICV hợp lệ mà không cần biết khóa giải mã.
- Thiếu cơ chế quản lý khóa động: WEP sử dụng khóa tĩnh cấu hình thủ công cho toàn bộ hệ thống. Việc không tự động xoay vòng khóa tạo điều kiện cho kẻ tấn công tích lũy đủ số lượng gói tin cần thiết.

Nhờ những lỗ hổng này, các kỹ thuật tấn công cải tiến như PTW (Pyshkin, Tews, Weinmann) có thể bẻ khóa hoàn toàn mạng WEP 128-bit chỉ trong vài giây sau khi thu thập đủ khoảng vài chục nghìn gói tin.

1.2.2. Giao thức WPA/WPA2 (Wi-Fi Protected Access) và cơ chế bắt tay 4 bước (4-way handshake)

a) Tổng quan về WPA và WPA2

Để giải quyết triệt để các lỗ hổng chí mạng của WEP, tổ chức Wi-Fi Alliance đã ban hành các giao thức thế hệ mới dựa trên chuẩn IEEE 802.11i:

- **WPA (Wi-Fi Protected Access - 2003):** Là giải pháp tạm thời nhằm nâng cấp bảo mật trên các phần cứng WEP cũ mà không cần thay đổi thiết bị. WPA sử dụng giao thức TKIP (Temporal Key Integrity Protocol) để mã hóa. TKIP vẫn dùng thuật toán RC4 nhưng bổ sung cơ chế trộn khóa cho mỗi gói tin (per-packet key) và mã kiểm tra tính toàn vẹn Michael MIC nhằm ngăn chặn tấn công giả mạo.
- **WPA2 (Wi-Fi Protected Access II - 2004):** Là chuẩn bảo mật hoàn chỉnh, bắt buộc thay đổi phần cứng hỗ trợ. WPA2 thay thế hoàn toàn RC4/TKIP bằng giao thức CCMP (Counter Mode Cipher Block Chaining Message Authentication Code Protocol) dựa trên thuật toán mã hóa tiên tiến AES (Advanced Encryption Standard), mang lại độ an toàn cực kỳ cao cho đến ngày nay.

b) Cấu trúc phân hệ khóa (Key Hierarchy)

Trong chế độ xác thực cá nhân (WPA/WPA2-PSK), hệ thống sử dụng một chuỗi các khóa được sinh ra theo phân cấp để mã hóa dữ liệu:

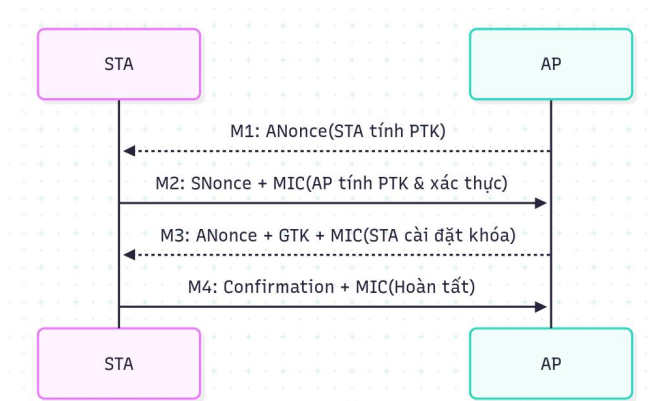
- **PSK (Pre-Shared Key):** Là mật khẩu Wi-Fi do người dùng thiết lập (từ 8 đến 63 ký tự).
- **PMK (Pairwise Master Key):** Khóa chính được tính toán cố định từ PSK và SSID thông qua hàm băm mật mã PBKDF2:

$$PMK = PBKDF2(\text{Passphrase}, \text{SSID}, 4096, 256)$$

- **PTK (Pairwise Transient Key):** Khóa tạm thời dùng để mã hóa lưu lượng đơn phát (Unicast) giữa một cặp STA và AP cụ thể. PTK được sinh ra bằng cách kết hợp: PMK, địa chỉ MAC của AP (AA), địa chỉ MAC của STA (SPA), giá trị ngẫu nhiên từ AP (ANonce), và giá trị ngẫu nhiên từ STA (SNonce).
- **GTK (Group Temporal Key):** Khóa dùng để mã hóa lưu lượng đa phát (Multicast/Broadcast) trong mạng.

c) Cơ chế bắt tay 4 bước (4-way Handshake)

Quá trình bắt tay 4 bước diễn ra sau khi STA hoàn thành liên kết (Association) với AP. Mục đích của quá trình này là để hai bên chứng minh với nhau rằng cùng sở hữu chung một PMK (mật khẩu) hợp lệ mà không cần truyền trực tiếp PMK qua sóng vô tuyến, đồng thời sinh ra khóa PTK để mã hóa dữ liệu.



Hình 1.4. Cơ chế bắt tay 4 bước (4-way Handshake)

Bước 1 (M1 - AP → STA): AP tạo ra một số ngẫu nhiên ANonce và gửi tới STA trong gói tin M1. Lúc này, STA đã có đầy đủ thông số (ANonce, SNonce tự tạo, AA, SPA, PMK) để tự tính toán ra khóa PTK.

Bước 2 (M2 - STA → AP): STA tạo ra số ngẫu nhiên SNonce và gửi cho AP gói tin M2 kèm theo một mã kiểm tra tính toàn vẹn dữ liệu MIC (Message Integrity Check) được tính toán bằng khóa PTK vừa tạo. Nhận được M2, AP tự tính toán PTK và đối chiếu mã MIC. Nếu khớp, AP xác nhận STA có mật khẩu đúng.

Bước 3 (M3 - AP → STA): AP gửi gói tin M3 chứa ANonce, khóa nhóm GTK đã mã hóa, và mã MIC đi kèm để chứng minh với STA rằng AP cũng sở hữu PMK hợp lệ. Nhận được M3, STA xác thực mã MIC và tiến hành cài đặt khóa PTK/GTK vào hệ thống.

Bước 4 (M4 - STA → AP): STA gửi gói tin M4 chứa mã MIC cuối cùng để xác nhận với AP rằng quá trình cài đặt khóa đã hoàn tất và sẵn sàng truyền tải dữ liệu mã hóa.

d) Lỗ hổng bảo mật của quá trình bắt tay 4 bước

Mặc dù thuật toán AES dùng trong WPA2 rất an toàn, nhưng quy trình bắt tay 4 bước lại tồn tại một điểm yếu chí mạng: Toàn bộ quá trình trao đổi 4 gói tin này diễn ra dưới dạng quảng bá không mã hóa trên không gian.

Kẻ tấn công có thể chủ động lắng nghe (sniffing) để thu thập trọn vẹn 4 gói tin bắt tay này. Vì gói tin M2 chứa giá trị SNonce và mã MIC (được tính bằng khóa PTK vốn suy ra từ PMK/Mật khẩu), kẻ tấn công có thể mang dữ liệu này về và thực hiện tấn công từ điển ngoại tuyến (Offline Dictionary Attack). Kẻ tấn công sẽ thử từng mật khẩu trong từ điển, tính toán PMK và PTK tương ứng, rồi so sánh với mã MIC thu được trong gói M2. Nếu khớp, mật khẩu mục tiêu sẽ bị bẻ khóa thành công. Đây chính là nguyên lý cốt lõi được áp dụng trong các công cụ thử nghiệm bảo mật Wi-Fi.

1.2.3. Giao thức WPA3 và cơ chế SAE (Simultaneous Authentication of Equals)

a) Tổng quan về WPA3

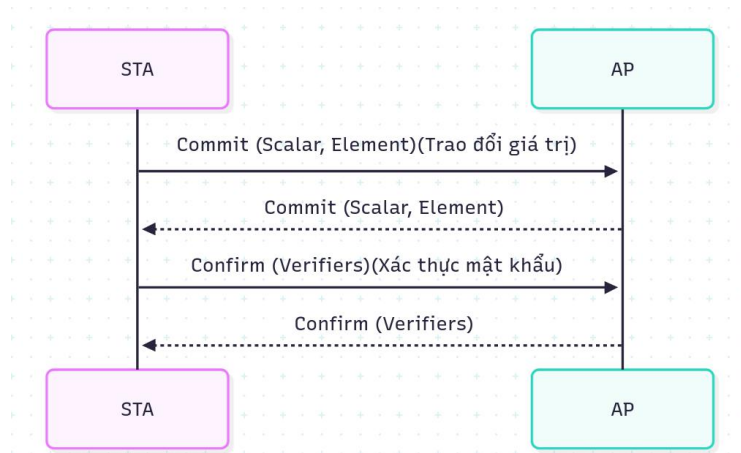
Giao thức WPA3 được tổ chức Wi-Fi Alliance ban hành vào năm 2018 nhằm thay thế cho WPA2 vốn đã bộc lộ nhiều điểm yếu sau gần hai thập kỷ hoạt động (đặc biệt là nguy cơ bị bẻ khóa mật khẩu qua việc thu giữ handshake và lỗ hổng KRACK).

WPA3 mang lại những cải tiến an ninh quan trọng bằng cách áp dụng các thuật toán mã hóa mạnh mẽ hơn, bắt buộc sử dụng tính năng bảo vệ khung quản lý PMF (Protected Management Frames) để chống lại các cuộc tấn công ngắt kết nối (Deauth), và thay đổi hoàn toàn cơ chế xác thực bắt tay ban đầu.

b) Cơ chế xác thực SAE (Simultaneous Authentication of Equals)

Trong chế độ cá nhân (WPA3-Personal), cơ chế bắt tay dựa trên PSK của WPA2 đã được thay thế hoàn toàn bằng giao thức SAE (Simultaneous Authentication of Equals), hay còn gọi là cơ chế trao đổi khóa Dragonfly.

SAE là một giao thức thỏa thuận khóa dựa trên kỹ thuật chứng minh không tiết lộ tri thức (Zero-Knowledge Proof) kết hợp với mật mã học đường cong elliptic (Elliptic Curve Cryptography - ECC) hoặc mật mã hóa trường hữu hạn (Finite Field Cryptography).



Hình 1.5. Cơ chế xác thực SAE

Tiến trình hoạt động của SAE gồm hai giai đoạn chính:

- Giai đoạn trao đổi giá trị (Commit Phase): Cả STA và AP cùng sử dụng mật khẩu Wi-Fi để ánh xạ thành một điểm chung trên đường cong elliptic, gọi là PWE (Password-Derived Element). Sau đó, mỗi bên tự chọn một số ngẫu nhiên riêng (Private Scalar) để thực hiện phép nhân điểm trên đường cong, sinh ra các giá trị công khai (Public Scalar và Element) và gửi cho nhau.
- Giai đoạn xác thực (Confirm Phase): Hai bên sử dụng các giá trị nhận được để tính toán ra một khóa bí mật chung (Shared Secret) và gửi các chuỗi kiểm chứng (Verifiers) cho đối phương nhằm chứng minh mình sở hữu đúng mật khẩu. Sau khi xác thực thành công, khóa chính PMK duy nhất cho phiên làm việc đó sẽ được thiết lập để chuyển tiếp sang quá trình bắt tay 4 bước (được sử dụng lại để sinh khóa mã hóa dữ liệu PTK).

c) Những cải tiến bảo mật vượt trội của WPA3

- Chống tấn công từ điển ngoại tuyến (Offline Dictionary Attack): Do tiến trình SAE không trao đổi các thông số giúp tính toán trực tiếp mã MIC như WPA2, kẻ tấn công dù bắt được gói tin cũng không thể bẻ khóa mật khẩu ngoại tuyến. Việc dò mật khẩu bắt buộc phải thực hiện trực tuyến (Active/Online) trực tiếp với AP và dễ bị ngăn chặn bởi cơ chế giới hạn số lần thử (rate limiting).

- Đảm bảo tính an toàn chuyển tiếp (Forward Secrecy): Nhờ cơ chế trao đổi khóa tạm thời (Ephemeral Diffie-Hellman), mỗi phiên làm việc sinh ra một khóa PMK độc lập. Ngay cả khi mật khẩu Wi-Fi chính thức bị lộ trong tương lai, kẻ tấn công cũng không thể giải mã dữ liệu đã thu giữ từ các phiên kết nối trong quá khứ.
- Mã hóa không dây cơ hội (OWE - Opportunistic Wireless Encryption): Giải pháp thay thế các mạng Wi-Fi công cộng mở (Open Hotspot). OWE tự động trao đổi khóa Diffie-Hellman để mã hóa lưu lượng riêng biệt cho từng người dùng mà không cần mật khẩu, ngăn chặn triệt để hành vi nghe lén thụ động (sniffing).

1.2.4. Cơ chế WPS (Wi-Fi Protected Setup)

a) Tổng quan về WPS

WPS (Wi-Fi Protected Setup) là một tiêu chuẩn mạng được tổ chức Wi-Fi Alliance ban hành năm 2006 nhằm đơn giản hóa quá trình thiết lập kết nối giữa các thiết bị trạm (STA - đặc biệt là các thiết bị không có màn hình hoặc bàn phím như máy in, camera, smart TV) với một mạng không dây được bảo mật bằng WPA/WPA2. Mục tiêu của WPS là giúp người dùng không có kiến thức kỹ thuật sâu vẫn có thể kết nối thiết bị mới vào mạng một cách nhanh chóng mà không cần nhập các chuỗi mật khẩu WPA phức tạp theo cách thủ công.

b) Các phương thức kết nối của WPS

- **Phương thức nút nhấn (Push Button Configuration - PBC):** Người dùng nhấn đồng thời nút vật lý (hoặc ảo) trên cả AP và STA trong một khoảng thời gian giới hạn (thường là 2 phút) để hai thiết bị tự động trao đổi khóa và kết nối. Phương thức này tương đối an toàn nhờ hạn chế tối đa thời gian mở cửa sổ ghép nối.
- **Phương thức mã PIN (WPS PIN):** Sử dụng một mã PIN tĩnh mặc định gồm 8 chữ số (in trên nhãn thiết bị) để xác thực kết nối. Người dùng phải nhập mã PIN này trên giao diện cấu hình của STA để thiết lập liên kết với AP. Đây là phương thức tồn tại các lỗ hổng bảo mật nghiêm trọng, dễ bị khai thác bởi kẻ tấn công.

c) Các lỗ hổng bảo mật nghiêm trọng của phương thức WPS PIN

- **Cấu trúc mã PIN và lỗ hổng xác thực tách biệt (Brute-force):** Mã PIN gồm 8 chữ số (108 tổ hợp), nhưng thực tế độ phức tạp giảm xuống chỉ còn 11,000 tổ hợp do:
 - + Chữ số thứ 8 là mã kiểm tra (Checksum), giảm không gian khóa xuống 10^7 tổ hợp.
 - + AP xác minh mã PIN theo hai nửa độc lập: 4 chữ số đầu ($10^4=10,000$ tổ hợp) và 3 chữ số tiếp theo ($10^3=1,000$ tổ hợp).
 - + Kẻ tấn công có thể thử riêng rẽ từng nửa mã PIN trực tuyến, giảm tổng số lần thử tối đa xuống $10,000+1,000=11,000$ lần. Quá trình này chỉ mất từ 2 đến 10 giờ bằng các công cụ tự động (Reaver, Bully) để lấy được mật khẩu WPA/WPA2 dạng bản rõ.
- **Tấn công Pixie Dust (Pixie-Dust Attack):** Lỗ hổng xảy ra do bộ sinh số ngẫu nhiên giả (PRNG) kém an toàn trên chipset của một số nhà sản xuất AP (như Realtek, Ralink, Broadcom).

- + Các giá trị ngẫu nhiên dùng để mã hóa PIN (E-S1, E-S2) được sinh ra từ các tham số dễ đoán (như thời gian hệ thống hoặc giá trị hạt giống cố định).
- + Kẻ tấn công chỉ cần thu giữ duy nhất một tiến trình bắt tay WPS (gói M1 đến M3), sau đó thực hiện bẻ khóa ngoại tuyến (Offline Brute-force) để khôi phục mã PIN trong vòng vài giây, hoàn toàn vượt qua cơ chế khóa bảo vệ (Lockout) của AP.

1.3. Các phương thức tấn công và lỗ hổng bảo mật Wi-Fi phổ biến

1.3.1. Tấn công từ chối dịch vụ (Deauthentication/Disassociation Attack)

a) Nguyên lý kỹ thuật

Cuộc tấn công này khai thác điểm yếu của tiêu chuẩn IEEE 802.11 gốc: Các khung quản lý (Management Frames) truyền đi dưới dạng bản rõ và không được xác thực nguồn gốc. Kẻ tấn công sử dụng card mạng ở chế độ giám sát (Monitor Mode) để giả mạo địa chỉ MAC và tiêm gói tin (Packet Injection) ngắt kết nối giả mạo.

Tiêu chí	Khung Deauthentication (Hủy xác thực)	Khung Disassociation (Hủy liên kết)
Cơ chế	Cắt đứt hoàn toàn quan hệ xác thực	Cắt đứt quan hệ liên kết logic
Trạng thái kết nối	Đưa STA về Trạng thái 1 (Chưa xác thực)	Đưa STA về Trạng thái 2 (Đã xác thực, chưa liên kết)
Mức độ ngắt	Triệt để, buộc phải thực hiện lại toàn bộ tiến trình	Nhẹ hơn, STA chỉ cần liên kết lại

Bảng 1.2. So sánh hai loại khung hình bị lợi dụng

b) Các kịch bản triển khai

- **Đích danh STA:** Giả mạo AP gửi gói Deauth tới địa chỉ MAC của STA mục tiêu → STA tự động rời mạng.
- **Đích danh AP:** Giả mạo STA gửi gói Deauth tới địa chỉ MAC của AP → AP hủy phiên làm việc của STA.
- **Quảng bá (Broadcast):** Gửi gói Deauth với địa chỉ đích là FF:FF:FF:FF:FF:FF → Ngắt kết nối đồng loạt toàn bộ thiết bị trạm trong mạng BSS.

c) Ý nghĩa kiểm thử và Giải pháp phòng chống

Mục đích trong kiểm thử bảo mật:

- Gây từ chối dịch vụ (DoS): Làm gián đoạn liên lạc mạng của mục tiêu.
- Thu thập Handshake: Ép thiết bị nạn nhân phải tự động kết nối lại, tạo cơ hội cho công cụ bắt giữ quá trình bắt tay 4 bước để bẻ khóa mật khẩu ngoại tuyến.
- Dẫn dụ sang Evil Twin: Ép nạn nhân mất kết nối với AP thật để tự động chuyển vùng sang AP giả mạo có sóng mạnh hơn.

Giải pháp phòng chống:

- Kích hoạt tính năng PMF / MFP (Protected Management Frames - chuẩn IEEE 802.11w).
- Tính năng này mã hóa và xác thực các khung quản lý, giúp AP và STA nhận biết và loại bỏ hoàn toàn các gói tin ngắt kết nối giả mạo. (Bắt buộc trên WPA3, tùy chọn cấu hình trên WPA2).

1.3.2. Tấn công thu thập Handshake và bể khóa mật khẩu (Offline Dictionary Attack)

a) Quy trình triển khai 2 giai đoạn

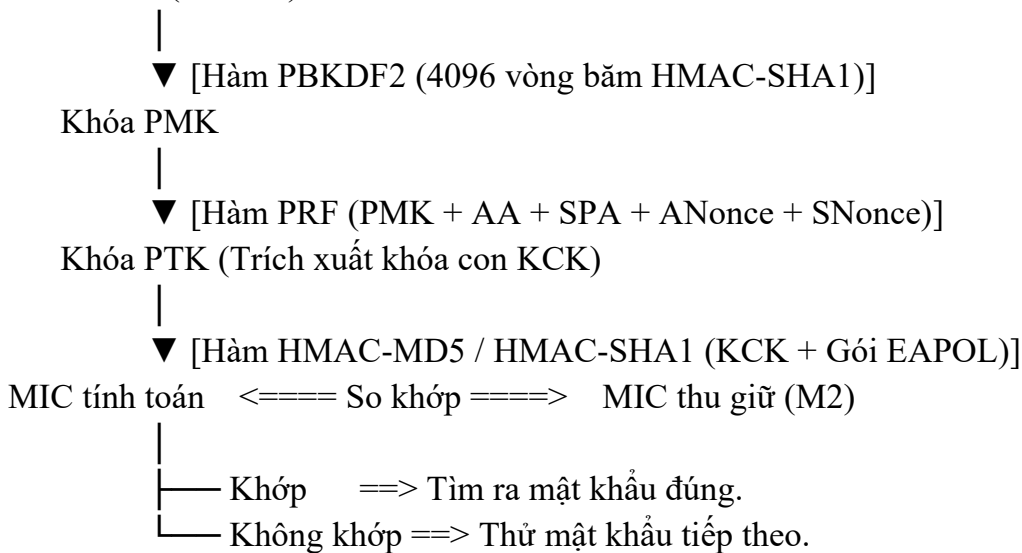
Giai đoạn 1: Thu thập Handshake trực tuyến (Online Capture):

Bước thực hiện	Mục đích	Dữ liệu thu giữ
1. Sniffing	Lắng nghe kênh tần số của AP mục tiêu ở chế độ Monitor Mode.	Địa chỉ MAC của AP (AA) và STA (SPA)
2. Deauth	Gửi gói Deauth ép STA ngắt kết nối và tự động kết nối lại.	-
3. Capture	Bắt trọn vẹn quá trình bắt tay 4 bước (gói M1 đến M4).	ANonce (từ AP), SNonce và MIC (từ gói M2 của STA)

Bảng 1.3. Thu thập Handshake trực tuyến

Giai đoạn 2: Bể khóa ngoại tuyến (Offline Cracking):

Mật khẩu thử (Từ điển) + SSID



b) Yếu tố kỹ thuật và Giải pháp phòng ngừa

Hiệu năng bể khóa: Do hàm PBKDF2 yêu cầu 4096 lượt lặp, tốc độ bể khóa trên CPU rất hạn chế. Trong thực tế, các công cụ (như Hashcat) sử dụng sức mạnh tính toán song song của GPU để tăng tốc độ thử nghiệm lên hàng trăm ngàn đến hàng triệu mật khẩu/giây.

Giải pháp phòng ngừa:

- Mật khẩu phức tạp: Đặt mật khẩu dài (>12 ký tự), không có trong từ điển để vô hiệu hóa phương pháp thử sai.
- Nâng cấp giao thức: Sử dụng WPA3 với cơ chế bắt tay SAE, loại bỏ hoàn toàn khả năng bể khóa ngoại tuyến từ các gói tin thu giữ được.

1.3.3. Tấn công giả mạo điểm truy cập (Evil Twin / Rogue AP)

a) Định nghĩa

Thuật ngữ	Khái niệm cốt lõi	Rủi ro chính
Rogue AP	Điểm truy cập trái phép cắm trực tiếp vào mạng nội bộ (LAN).	Tạo cổng sau (Backdoor) giúp bypass tường lửa để xâm nhập mạng LAN.

Evil Twin	AP giả mạo cấu hình trùng tên (SSID) và địa chỉ MAC (BSSID) của AP thật.	Dẫn dụ thiết bị nạn nhân kết nối để thực hiện tấn công nghe lén (MitM).
------------------	--	---

Bảng 1.4. Định nghĩa Evil Twin và Rogue AP

b) Tiến trình tấn công Evil Twin (4 Bước)

Bước 1: Khảo sát (Reconnaissance): Quét mục tiêu để lấy SSID, BSSID và Kênh tần số của AP thật.

Bước 2: Thiết lập (Setup): Khởi tạo AP giả mạo trùng tên SSID, nhân bản BSSID (MAC Spoofing) và phát công suất sóng mạnh hơn AP thật.

Bước 3: Ngắt kết nối (Deauth): Gửi liên tục gói Deauth để ép các STA rút mạng khỏi AP thật.

Bước 4: Khai thác (Exploit): STA tự động kết nối sang AP giả mạo có sóng mạnh nhất. Kẻ tấn công đóng vai trò Gateway trung gian để:

- Dựng trang chào giả mạo (Captive Portal) lừa người dùng nhập mật khẩu Wi-Fi.
- Thực hiện tấn công Man-in-the-Middle để nghe lén và đánh cắp thông tin.

c) Giải pháp phòng chống

Đối với Người dùng:

- Tắt tính năng tự động kết nối Wi-Fi công cộng.
- Sử dụng VPN để mã hóa toàn bộ dữ liệu truyền tải qua mạng không dây.

Đối với Quản trị viên:

- Sử dụng chuẩn xác thực doanh nghiệp 802.1X (WPA2/WPA3-Enterprise) yêu cầu kiểm tra chứng chỉ số (Certificate) của máy chủ RADIUS để chống giả mạo AP.
- Triển khai hệ thống giám sát WIDS/WIPS để phát hiện các AP phát sóng trùng SSID/BSSID bất thường.

1.3.4. Khai thác lỗ hổng WPS (Pixie Dust, PIN brute-force)

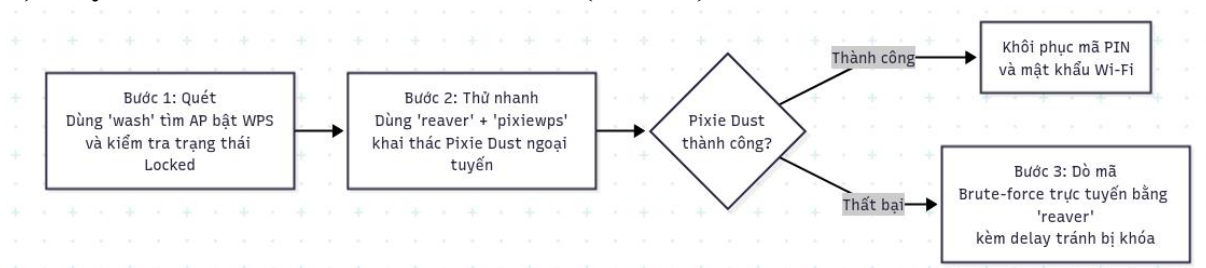
a) So sánh hai phương thức khai thác WPS

Tiêu chí so sánh	Tấn công dò mã trực tuyến (WPS PIN Brute-force)	Tấn công bẻ khóa ngoại tuyến (Pixie Dust Attack)
Cơ chế hoạt động	Gửi liên tục các mã PIN giả lập tới AP để xác thực trực tiếp.	Thu thập gói tin bắt tay (M1-M3) chứa dữ liệu mã hóa, sau đó bẻ khóa ngoại tuyến.
Độ phức tạp	Thử tối đa $10,000 + 1,000 = 11,000$ tổ hợp nhờ cơ chế xác minh tách biệt.	Bẻ khóa ngược các tham số ngẫu nhiên (E-S1, E-S2) dựa trên lỗi PRNG của chipset AP.
Thời gian thực thi	Từ 2 đến 10 giờ.	Vài giây đến vài phút.
Khả năng bị chặn	Dễ bị khóa bởi cơ chế chống Brute-force trực tuyến (WPS Lockout).	Vượt qua hoàn toàn cơ chế khóa bảo vệ (chỉ cần tương tác 1 lần để lấy gói tin).

Công cụ tiêu biểu	Reaver, Bully	Pixiewps (tích hợp trong Reaver/Bully)

Bảng 1.5. So sánh hai phương thức khai thác WPS

b) Quy trình triển khai kiểm thử WPS (3 Bước)



Hình 1.6. Quy trình triển khai kiểm thử WPS

c) Giải pháp phòng chống

Vô hiệu hóa WPS PIN: Tắt hoàn toàn tính năng xác thực bằng mã PIN trên AP.

Sử dụng PBC: Chỉ kích hoạt phương thức nút nhấn vật lý (PBC) khi cần kết nối thiết bị mới.

Tắt hoàn toàn WPS: Giải pháp an toàn nhất là tắt hoàn toàn dịch vụ WPS trên thiết bị định tuyến.

CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

2.1. Phân tích yêu cầu hệ thống

2.1.1. Yêu cầu chức năng

Chức năng Quét và Thu thập (Scan): Hệ thống phải có khả năng tương tác với card mạng không dây, chuyển đổi linh hoạt giữa các chế độ hoạt động để quét không gian sóng vô tuyến. Quá trình quét cần thu thập đầy đủ các tham số kỹ thuật của các Trạm phát sóng (Access Point) lân cận như: Tên mạng (SSID), Địa chỉ vật lý (MAC/BSSID), Kênh truyền (Channel), Chuẩn mã hóa đang sử dụng, và Cường độ tín hiệu.

Chức năng Phân tích và Đánh giá (Analyze): Dựa trên dữ liệu quét được, hệ thống cần có bộ lọc và động cơ phân tích để đánh giá mức độ an toàn của từng mạng. Phải chỉ ra được các điểm yếu cấu hình (ví dụ: sử dụng chuẩn mã hóa cũ, không có mật khẩu) và phân loại mức độ rủi ro tương ứng.

Chức năng Tấn công mô phỏng (Attack): Đây là phân hệ kiểm thử xâm nhập thực tế, yêu cầu thực hiện chuỗi hành động:

- Gửi các gói tin ngắt kết nối (Deauthentication) nhằm ép các thiết bị đang kết nối trong mạng mục tiêu phải ngắt và kết nối lại.
- Tự động lắng nghe và thu thập các gói tin thỏa thuận khóa (4-Way Handshake) phát sinh trong quá trình thiết bị kết nối lại.
- Thực hiện bẻ khóa ngoại tuyến (Offline Cracking) dựa trên tệp từ điển để truy xuất mật khẩu gốc.

Chức năng Lập báo cáo (Generate Report): Tổng hợp toàn bộ kết quả từ quá trình quét, phân tích và tấn công để tự động kết xuất thành một tài liệu báo cáo chuyên nghiệp (định dạng PDF), phục vụ cho việc lưu trữ và khắc phục sự cố.

2.1.2. Yêu cầu phi chức năng

Tính ổn định và Xử lý đa luồng (Multithreading): Các tác vụ như quét mạng hay dò mật khẩu thường tiêu tốn nhiều thời gian và tài nguyên phần cứng. Hệ thống bắt buộc phải xử lý các tác vụ này ở các tiến trình nền độc lập để đảm bảo giao diện người dùng không bị "đóng băng" (freeze) hay gián đoạn trong lúc chờ đợi kết quả.

Giao diện trực quan và Dễ sử dụng: Phải loại bỏ sự rườm rà của các dòng lệnh phức tạp. Giao diện cần được thiết kế theo hướng phân trang (mỗi chức năng là một trang riêng biệt), hiển thị dữ liệu dưới dạng bảng biểu rõ ràng và có các biểu tượng, màu sắc cảnh báo trực quan.

Đặc quyền hệ thống: Do tính chất can thiệp sâu vào phần cứng mạng, phần mềm yêu cầu phải được thực thi dưới quyền quản trị trị cao nhất (root/administrator) trên môi trường hệ điều hành lõi Linux.

2.2. Thiết kế kiến trúc phần mềm

2.2.1. Kiến trúc tổng thể

Kiến trúc của phần mềm được lấy cảm hứng từ mô hình MVC (Model - View - Controller), kết hợp với thiết kế giao diện đa trang (Page-based Navigation). Sự phân tách này giúp mã nguồn dễ bảo trì, dễ mở rộng và giảm thiểu sự phụ thuộc lẫn nhau.

- Lớp Giao diện (View): Được xây dựng dựa trên framework đồ họa hiện đại. Giao diện chính đóng vai trò như một bộ khung chứa (container), cho phép người dùng chuyển đổi qua lại giữa các phân hệ chức năng (Bảng điều khiển, Quét mạng, Đánh giá, Tấn công). Mọi thao tác của người dùng trên lớp này (nhấn nút, chọn mục) sẽ phát ra các sự kiện.
- Lớp Điều khiển (Controller): Đóng vai trò cầu nối. Khi nhận được sự kiện từ lớp Giao diện, lớp Điều khiển sẽ kiểm tra tính hợp lệ của dữ liệu đầu vào, sau đó gọi đến các dịch vụ tương ứng ở lớp Xử lý logic. Đồng thời, nó cũng chịu trách nhiệm nhận kết quả trả về để cập nhật lên màn hình.
- Lớp Xử lý Logic (Services/Model): Đây là "bộ não" của hệ thống, bao gồm các module độc lập đảm nhiệm các nghiệp vụ cụ thể. Các module này không tương tác trực tiếp với giao diện mà thực hiện nhiệm vụ gọi lệnh hệ thống (thao tác với công cụ mạng), xử lý tệp tin, phân tích chuỗi văn bản đầu ra và tính toán kết quả.

2.2.2. Thiết kế cơ chế đa luồng cho các tác vụ mạng

Thách thức lớn nhất trong việc phát triển ứng dụng đồ họa có tương tác với các công cụ mạng là việc quản lý tiến trình. Nếu thực thi một lệnh quét mạng trực tiếp trên luồng chính của ứng dụng, toàn bộ giao diện sẽ bị treo cho đến khi lệnh đó kết thúc.

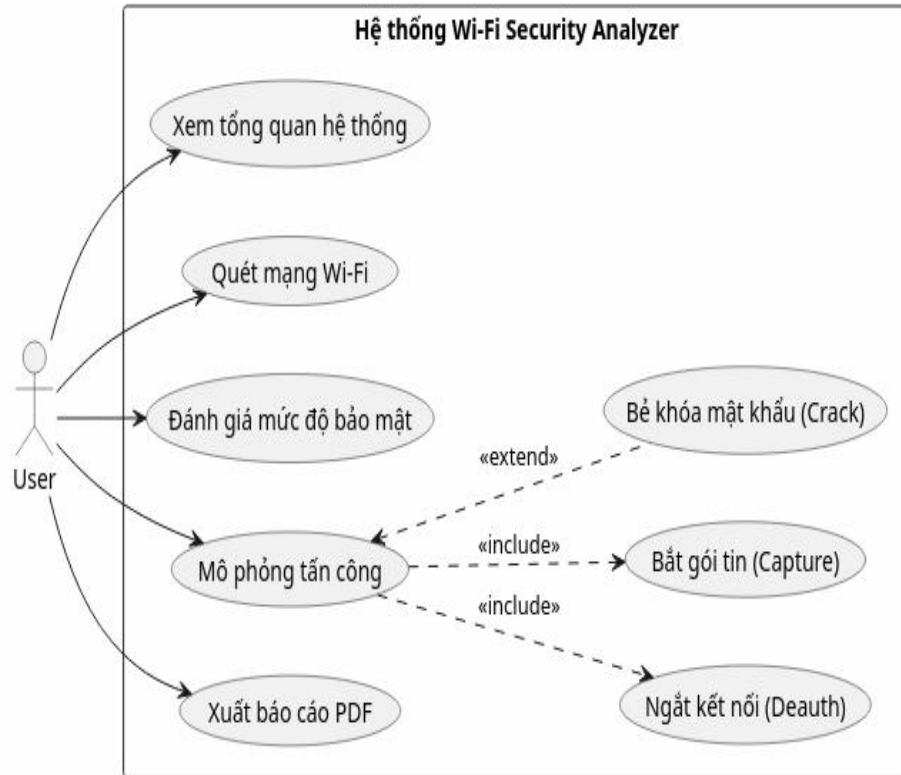
Để giải quyết vấn đề này, hệ thống áp dụng Kiến trúc Công nhân (Worker/Thread Pattern):

- **Phân tách luồng:** Luồng chính (Main Thread) chỉ chịu trách nhiệm duy nhất là hiển thị giao diện và tiếp nhận tương tác của người dùng. Mọi tác vụ nặng (như quét AP, gửi Deauth, bắt Handshake, bẻ khóa) đều được đẩy sang các luồng công nhân (Worker Threads) hoạt động ngầm.
- **Cơ chế giao tiếp an toàn (Event-driven):** Các luồng công nhân không được phép can thiệp trực tiếp vào giao diện (việc này sẽ gây lỗi tràn bộ nhớ hoặc xung đột). Thay vào đó, hệ thống sử dụng cơ chế phát và nhận tín hiệu.
- **Luồng hoạt động:** Khi luồng công nhân đang thực thi, nó sẽ liên tục đọc dữ liệu đầu ra từ các công cụ mạng (ví dụ: đọc dòng log, cập nhật tiến độ phần trăm).
 - + Mỗi khi có dữ liệu mới, luồng công nhân đóng gói dữ liệu đó và "phát" đi một tín hiệu.
 - + Luồng chính "lắng nghe" tín hiệu này, nhận dữ liệu một cách an toàn và tiến hành cập nhật lên bảng hiển thị hoặc thanh trạng thái.
 - + Khi tác vụ hoàn thành hoặc có lỗi xảy ra, luồng công nhân phát tín hiệu kết thúc để luồng chính giải phóng tài nguyên và thông báo cho người dùng.

Cơ chế này đảm bảo phần mềm hoạt động vô cùng mượt mà, có thể theo dõi trực tiếp các dòng log (nhật ký) của quá trình tấn công theo thời gian thực mà không gặp bất kỳ độ trễ nào về mặt giao diện.

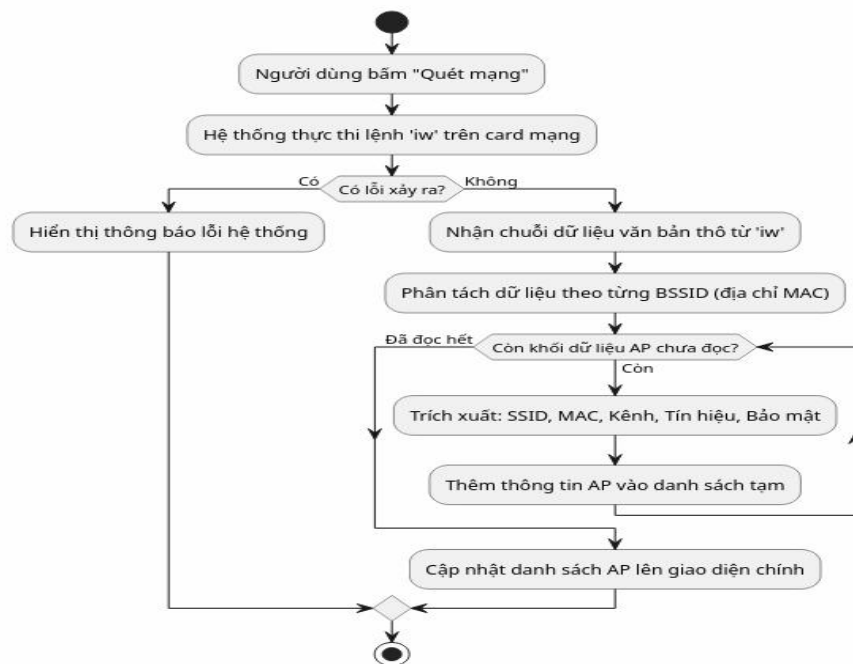
2.3. Mô hình hóa hệ thống

2.3.1. Biểu đồ Use Case



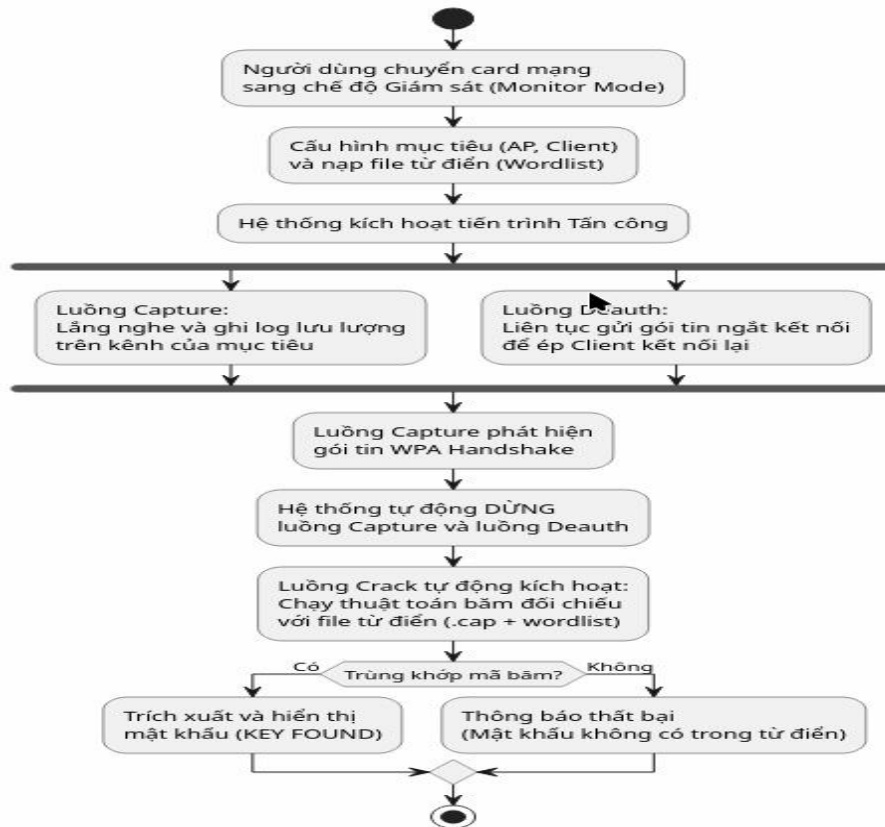
Hình 2.1. Biểu đồ User case

2.3.2. Biểu đồ Hoạt động (Activity Diagram) – Luồng quét và thu thập thông số AP



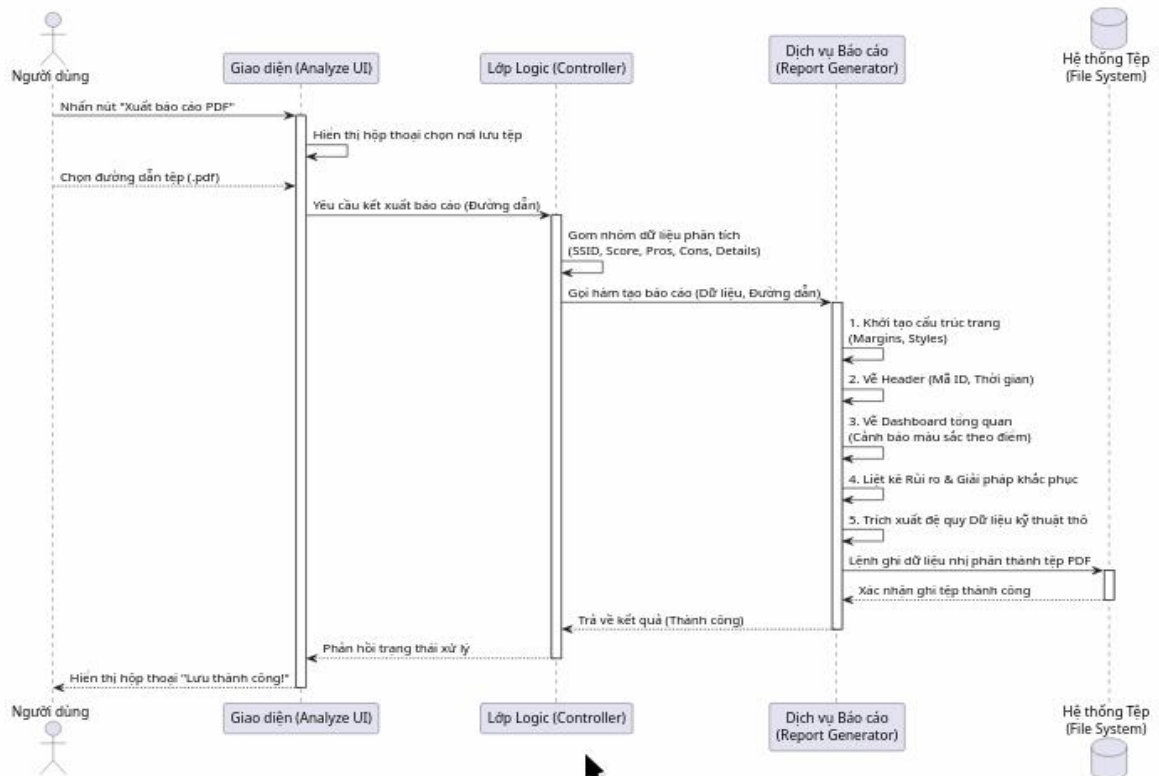
Hình 2.2. Biểu đồ Hoạt động luồng quét và thu thập thông số AP

2.3.3. Biểu đồ Hoạt động (Activity Diagram) – Luồng mô phỏng tấn công (Deauth -> Capture -> Crack)



Hình 2.3. Biểu đồ Hoạt động luồng mô phỏng tấn công

2.3.4. Biểu đồ Tuần tự (Sequence Diagram) – Quá trình xuất báo cáo đánh giá bảo mật (PDF)



Hình 2.4. Biểu đồ Tuần tự quá trình xuất báo cáo đánh giá bảo mật

2.4. Thiết kế thuật toán và động cơ xử lý

2.4.1. Thuật toán phân tích và chấm điểm rủi ro bảo mật

Thay vì chỉ hiển thị thông tin mạng đơn thuần, hệ thống được tích hợp một động cơ chấm điểm bảo mật (Scoring Engine) hoạt động dựa trên các bộ quy tắc (Heuristic Rules). Thuật toán này sử dụng cơ chế điểm cơ sở (Base Score) kết hợp với các trọng số cộng/trừ để đánh giá toàn diện cấu hình của một điểm truy cập.

Cơ chế hoạt động của thuật toán diễn ra theo các bước phân tích sau:

- **Khởi tạo điểm cơ sở:** Mọi mạng Wi-Fi ban đầu được gán một mức điểm chuẩn là 80/100 (đại diện cho cấu hình tiêu chuẩn phổ biến hiện nay: WPA2 kết hợp mã hóa AES).
- **Quy tắc loại trừ trực tiếp (Critical Failures):** Thuật toán thực hiện kiểm tra các lỗ hổng nghiêm trọng đầu tiên. Nếu phát hiện mạng không sử dụng mật khẩu (Open Network) hoặc sử dụng chuẩn WEP đã bị phá vỡ hoàn toàn, điểm số lập tức bị trả về 0, đồng thời hệ thống phát cảnh báo đỏ độc lập với các thông số khác.
- **Đánh giá Giao thức và Mã hóa (Protocol & Cipher):** Hệ thống thưởng điểm mạnh (+20 điểm) cho các mạng áp dụng chuẩn WPA3 thuần túy do khả năng chống tấn công từ điển ưu việt. Đối với chế độ hỗn hợp WPA2/WPA3, mức thưởng thấp hơn (+5 điểm) do vẫn còn rủi ro hạ cấp giao thức (Downgrade Attack).
- **Ngược lại,** hệ thống phạt rất nặng (-30 đến -50 điểm) đối với các mạng duy trì chuẩn WPA1 cũ hoặc chế độ hỗn hợp WPA1/WPA2. Nếu phát hiện thuật toán mã hóa luồng yếu (như TKIP), hệ thống tiếp tục trừ điểm (-20 điểm).

Đánh giá Cơ chế Xác thực và Tính năng mở rộng:

- Các mạng sử dụng cơ chế xác thực doanh nghiệp (802.1X/EAP) được cộng thêm điểm (+15 điểm) nhờ tính bảo mật cao của xác thực đa người dùng.
- Thuật toán quét sâu vào dữ liệu khung để tìm kiếm tính năng WPS (Wi-Fi Protected Setup). Nếu WPS đang được bật, hệ thống trừ mức điểm lớn (-30 điểm) do đây là lỗ hổng chí mạng cho phép kẻ tấn công dò mã PIN dễ dàng.
- Hệ thống cũng kiểm tra cờ báo hiệu của Tính năng bảo vệ khung quản lý (Management Frame Protection - MFP). Sự hiện diện của MFP sẽ giúp cộng điểm, trong khi việc thiếu vắng tính năng này sẽ bị phạt (-10 điểm) vì mạng có nguy cơ bị tấn công ngắt kết nối.

Chuẩn hóa và Tổng hợp: Sau khi đi qua toàn bộ bộ lọc, tổng điểm được chuẩn hóa (Normalization) để luôn nằm trong khoảng từ 0 đến 100. Dựa vào điểm số cuối cùng và các cờ vi phạm, thuật toán sẽ tự động phát sinh danh sách các ưu điểm (Pros), các rủi ro (Cons) và đề xuất biện pháp khắc phục tương ứng để đưa vào báo cáo.

2.4.2. Cơ chế giám sát và bắt gói tin Handshake tự động

Trong giai đoạn kiểm thử xâm nhập, việc thu thập thành công gói tin thỏa thuận khóa (WPA Handshake) là điều kiện tiên quyết để tiến hành bẻ khóa. Thuật toán bắt gói tin được thiết kế theo mô hình "Kiểm tra chủ động" (Active Polling) chạy trên một tiến trình nền hoàn toàn độc lập với giao diện chính.

Cơ chế hoạt động của động cơ giám sát diễn ra theo trình tự khép kín như sau:

- **Khởi tạo và Cách ly môi trường:** Khi nhận được lệnh, luồng giám sát sẽ định tuyến nơi lưu trữ tệp tin tạm thời vào thư mục hệ thống (ví dụ: /tmp) và tự động dọn dẹp các tệp tin giám sát cũ. Thao tác này nhằm đảm bảo kết quả phân tích không bị lẫn lộn với các phiên làm việc trước đó. Động cơ cũng thiết lập một phiên làm việc mới cho tiến trình (Process Group) để đảm bảo việc quản lý vòng đời tiến trình được chặt chẽ.
- **Kích hoạt Lắng nghe:** Động cơ gọi lệnh hệ thống bằng đặc quyền quản trị, cấu hình card mạng tập trung lắng nghe duy nhất trên kênh truyền (Channel) và địa chỉ MAC (BSSID) của mục tiêu. Việc ghi dữ liệu xuống tệp tin được thiết lập tần suất cao (ví dụ: 1 giây/lần) để tránh bỏ sót các gói tin đến trễ.
- **Vòng lặp Kiểm tra chéo (Polling Loop):** Thay vì chỉ lắng nghe thụ động và bắt người dùng tự phán đoán thời điểm kết thúc, động cơ triển khai một vòng lặp kiểm tra định kỳ (cứ mỗi 3 giây). Vòng lặp này sẽ sử dụng một bộ phân tích gói tin thứ hai để đọc tệp dữ liệu đang được ghi.
- **Nhận diện chữ ký và Dừng tiến trình:** Bộ phân tích liên tục tìm kiếm chữ ký của quá trình "4-Way Handshake". Ngay khi chuỗi xác thực được tìm thấy trong tệp dữ liệu, vòng lặp lập tức bị phá vỡ.
- **Đồng bộ hóa tín hiệu an toàn:** Động cơ tiến hành gửi tín hiệu ngắt an toàn (SIGINT) đến bộ công cụ lắng nghe để đảm bảo tệp tin thu thập không bị lỗi định dạng (corrupted). Cuối cùng, nó phát ra một tín hiệu nội bộ mang theo đường dẫn của tệp tin vừa thu thập được, thông báo cho hệ thống trung tâm tự động chuyển sang giai đoạn bẻ khóa mật khẩu.

Nội dung trên đã bao quát toàn bộ logic kỹ thuật tinh tế trong hệ thống của bạn (từ tính điểm, phân tích TKIP, WPS, MFP cho đến cơ chế tự động check file .cap mỗi 3 giây và gửi tín hiệu ngắt OS an toàn).

CHƯƠNG 3. TRIỂN KHAI ĐỀ TÀI

3.1. Môi trường phát triển và cấu hình triển khai

3.1.1. Yêu cầu phần cứng và card mạng

Chế độ giám sát (Monitor Mode): Cho phép thiết bị lắng nghe, thu thập toàn bộ lưu lượng vô tuyến đang truyền tải trên một kênh cụ thể (Channel) mà không cần xác thực hay kết nối vào Access Point. Đây là điều kiện bắt buộc để bắt được gói tin WPA Handshake.

Tiêm gói tin (Packet Injection): Khả năng chế tạo và phát sóng các khung mạng (frames) giả mạo vào môi trường không gian (ví dụ: gửi gói tin ngắt kết nối Deauthentication) để chủ động tương tác với mục tiêu.

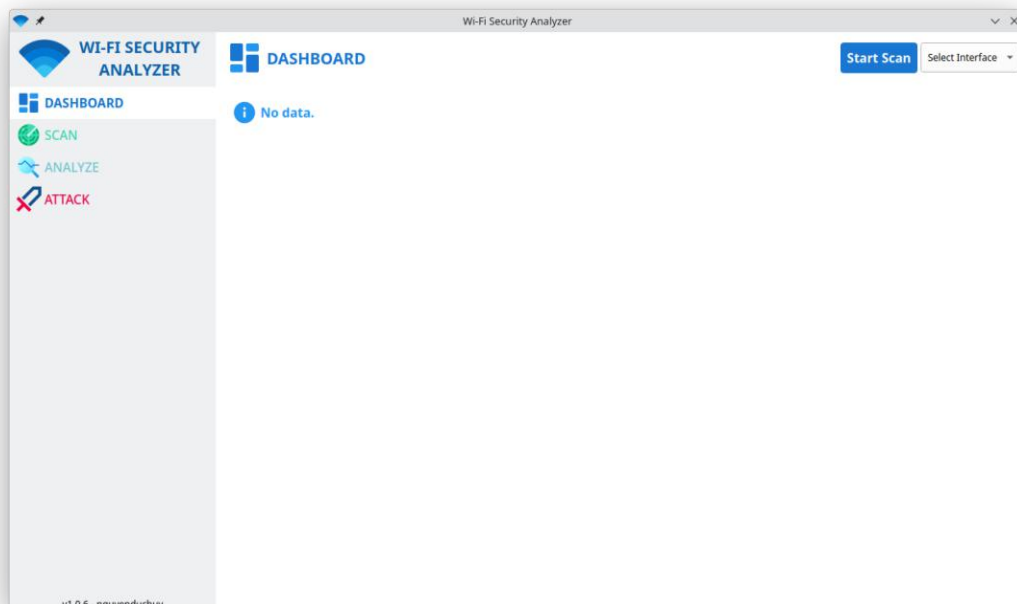
3.1.2. Môi trường phần mềm

Hệ điều hành lõi (Linux OS): Hệ thống yêu cầu triển khai bắt buộc trên nền tảng Linux (như Kali Linux, Parrot OS, Ubuntu). Nguyên nhân là do ứng dụng cần đặc quyền truy cập sâu vào nhân hệ điều hành (Kernel) để quản lý driver mạng và sử dụng trực tiếp các bộ công cụ dòng lệnh đặc thù (chạy dưới quyền root) như iw và aircrack-ng suite.

Môi trường lập trình (Python Virtual Environment): Mã nguồn ứng dụng được viết bằng Python 3.x. Để tránh xung đột thư viện với hệ điều hành, hệ thống được đóng gói trong một môi trường ảo (venv). Các thư viện cốt lõi được sử dụng bao gồm: PySide6 (xây dựng giao diện đồ họa GUI và quản lý đa luồng) và ReportLab (tổng hợp dữ liệu và kết xuất báo cáo PDF tự động).

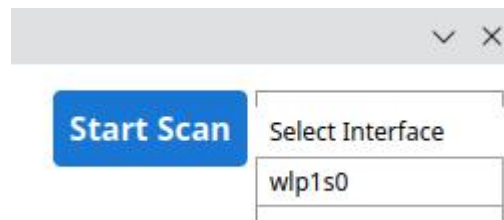
3.2. Triển khai các phân hệ chức năng chính

3.2.1. Phân hệ Bảng điều khiển giám sát tổng quan (Dashboard Page)



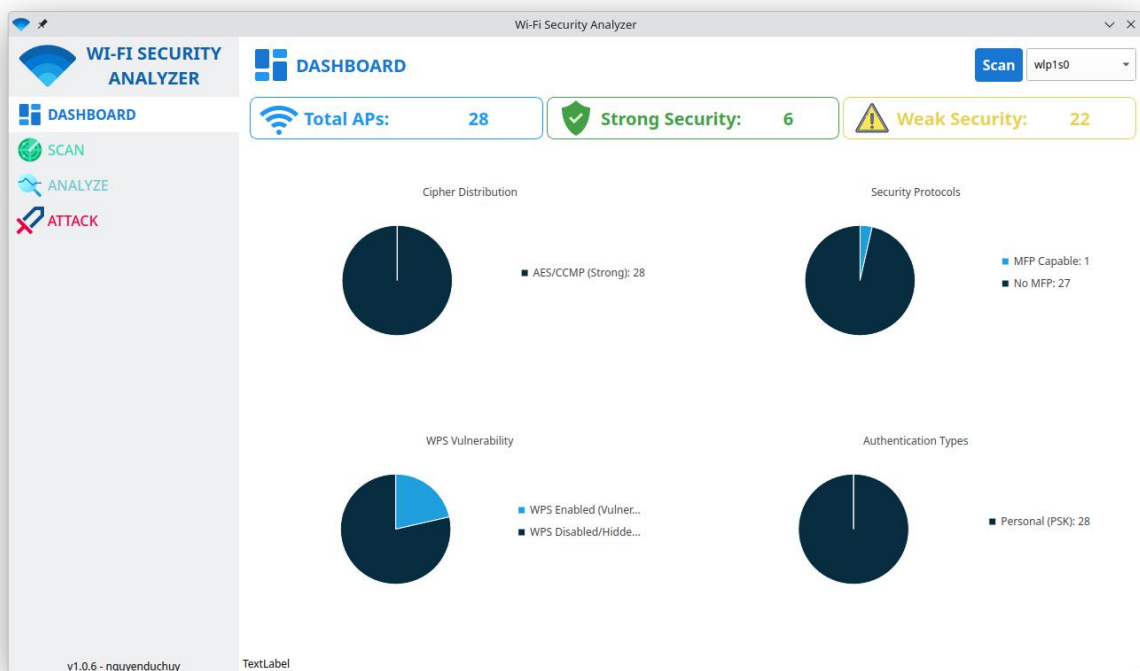
Hình 3.1. Giao diện Dashboard trước khi quét

Giao diện mặc định của Bảng điều khiển tổng quan (Dashboard) khi phần mềm vừa được khởi động và chưa tiến hành rà quét mạng.



Hình 3.2. Giao diện chọn interface

Chọn giao diện mạng để tiến hành quét các wifi xung quanh



Hình 3.3. Giao diện Dashboard sau khi quét

Hệ thống sử dụng các thẻ tóm tắt (Cards) với màu sắc chỉ thị (Xanh cho an toàn, Vàng cho cảnh báo) để báo cáo nhanh số lượng: Tổng số điểm truy cập (28), số mạng có bảo mật mạnh (6) và số mạng có bảo mật yếu (22).

Phần trung tâm của giao diện sử dụng các biểu đồ tròn (Pie Charts) để trực quan hóa các thông số kỹ thuật phức tạp, giúp đánh giá nhanh hệ thống mạng:

- **Cipher Distribution:** Thống kê các thuật toán mã hóa (như AES/CCMP).
- **Security Protocols:** Phân tích các giao thức bảo mật, đặc biệt là tính năng chống tấn công giả mạo (MFP).
- **WPS Vulnerability:** Cảnh báo các mạng đang bật tính năng WPS
- **Authentication Types:** Thống kê các phương thức xác thực người dùng (như WPA2-PSK).

3.2.2. Phân hệ Quét và trích xuất thông tin Access Point (Scan Page)



WI-FI SECURITY ANALYZER

DASHBOARD

SCAN

ANALYZE

ATTACK

Wi-Fi Security Analyzer

IN-USE

SSID

BSSID

SIGNAL

BARS

CHANNEL

BANDWIDTH

SECURITY

1	P212	4C:12:E8:59:B1:70	34%		1	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES) [WPS Enabled - Vulnerable]
2	213	CC:71:90:8B:41:08	58%		1	2.4 GHz	Medium Risk (WPA2-PSK AES)
3	P306	CC:71:90:8B:57:C0	90%		3	2.4 GHz	Medium Risk (WPA2-PSK AES)
4	P420-2	4C:12:E8:E8:21:38	86%		4	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
5	Trum day 2	4C:12:E8:32:10:B0	74%		6	2.4 GHz	Medium Risk (WPA2-PSK AES)
6	P419	CC:71:90:D6:04:48	100%		6	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
7	511-2	4C:12:E8:E8:05:B8	66%		6	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
8	P319	4C:12:E8:32:6B:08	86%		9	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
9	P512	CC:71:90:8B:55:78	82%		9	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
10	P306 5G	CC:71:90:8B:57:C1	64%		36	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
11	P419 5G	CC:71:90:D6:04:49	100%		36	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
12	P419/3 5G	CC:71:90:8B:A4:B9	42%		60	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
13	P413 5G	CC:71:90:9C:06:69	42%		104	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
14	P412 5G	CC:71:90:09:F9:B9	42%		112	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
15	P420-2 5G	4C:12:E8:E8:21:39	62%		120	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
16	P513_5G	4C:12:E8:32:1F:41	42%		124	5 GHz	High Risk (Mixed WPA1/WPA2 AES)
17	Phong Tu Tri 5G	4C:12:E8:47:9B:09	42%		128	5 GHz	High Risk (Mixed WPA1/WPA2 AES) [WPS Enabled - Vulnerable]
18	P421	D4:9A:A0:BE:7F:B8	58%		3	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)
19	P409	4C:12:E8:32:43:C0	44%		1	2.4 GHz	Medium Risk (WPA2-PSK AES)
20	P214	4C:12:E8:26:C6:30	34%		1	2.4 GHz	High Risk (Mixed WPA1/WPA2 AES)

v1.0.6 - nguyenduchuy

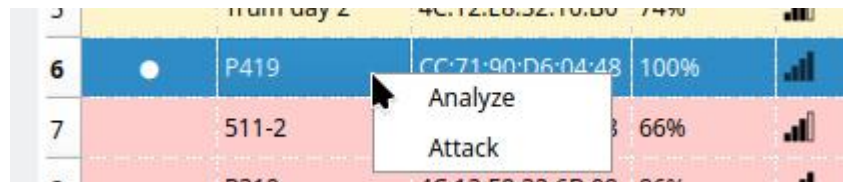
Hình 3.4. Giao diện Scan

Hình ảnh hiển thị giao diện của trang Scan, đây là thành phần chịu trách nhiệm thu thập và hiển thị danh sách các mạng không dây trong phạm vi hoạt động. Dữ liệu được trình bày dưới dạng bảng chi tiết, cho phép theo dõi toàn diện các thông số kỹ thuật của từng điểm truy cập:

- **SSID và BSSID:** Hiển thị tên mạng và địa chỉ vật lý (MAC) của các thiết bị phát sóng.
- **Signal và Bars:** Thể hiện cường độ tín hiệu theo đơn vị phần trăm (%) và biểu tượng cột sóng để đánh giá độ ổn định của kết nối.
- **Channel và Bandwidth:** Cung cấp thông tin về kênh truyền hiện tại và băng tần hoạt động (2.4 GHz hoặc 5 GHz), giúp nhận diện sự chồng chéo kênh sóng.
- **Security:** Đây là cột quan trọng nhất, hiển thị kết quả phân tích sơ bộ về giao thức bảo mật và thuật toán mã hóa đang được áp dụng.

Hệ thống triển khai thuật toán đánh giá tự động và trực quan hóa thông qua mã màu trên các dòng dữ liệu:

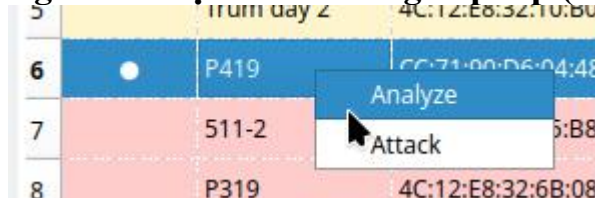
- **Màu đỏ (High Risk):** Cảnh báo các mạng có mức độ nguy hiểm cao. Những mạng này thường sử dụng các giao thức cũ (Mixed WPA1/WPA2) hoặc đang bật tính năng WPS (WPS Enabled - Vulnerable), vốn là những lỗ hổng dễ bị khai thác thông qua các kỹ thuật tấn công mã PIN hoặc Brute-force.
- **Màu vàng (Medium Risk):** Chỉ định các mạng có mức độ an toàn trung bình, thường sử dụng chuẩn WPA2-PSK AES



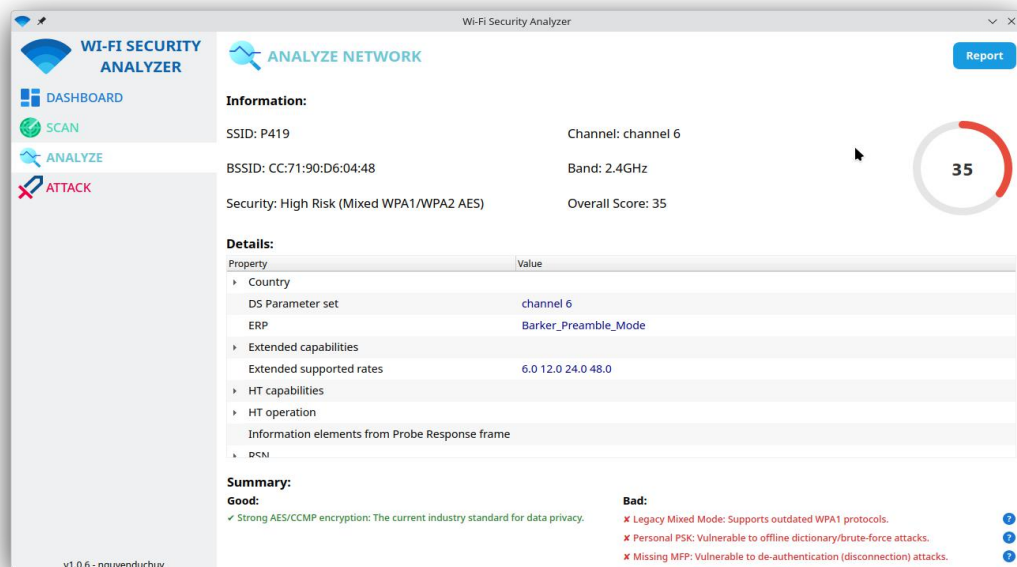
Hình 3.5. Các tùy chọn cho wifi

Khi thao tác trực tiếp vào một dòng dữ liệu cụ thể trong bảng danh sách (ví dụ mạng P419), menu sẽ hiển thị hai tác vụ chính là Analyze (Phân tích) và Attack (Tấn công).

3.2.3. Phân hệ Đánh giá bảo mật và đề xuất giải pháp (Analyze Page)



Hình 3.6. Chọn tính năng phân tích



Hình 3.7. Giao diện Analyze

Phần trên cùng của giao diện liệt kê các thông số định danh cơ bản của mục tiêu như SSID, BSSID, kênh truyền và băng tần hoạt động.

Hệ thống triển khai một cơ chế chấm điểm tự động (**Overall Score**). Trong hình minh họa, mạng P419 chỉ đạt 35 điểm, được trực quan hóa bằng biểu đồ vòng tròn màu đỏ. Con số này phản ánh mức độ rủi ro cao dựa trên các tiêu chí bảo mật được thiết lập sẵn trong thuật toán của ứng dụng.

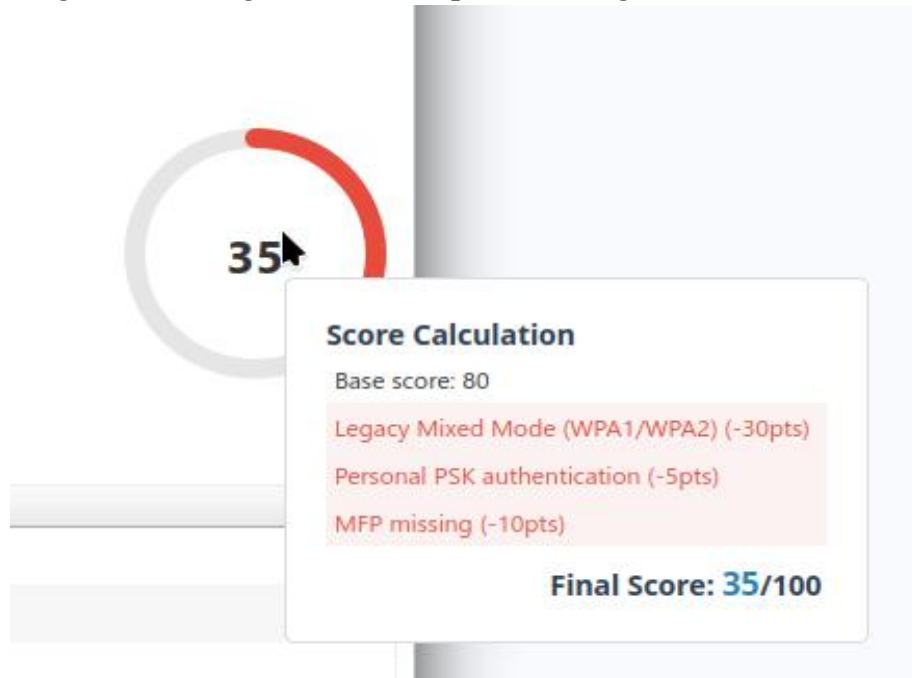
Khu vực **Details** hiển thị một bảng dữ liệu cấu trúc cây, liệt kê chi tiết các thành phần thông tin (Information Elements) thu thập được từ các khung quản trị (Management Frames) như Beacon hay Probe Response.

Good (Ưu điểm): Ghi nhận các điểm tích cực như việc sử dụng thuật toán mã hóa mạnh (AES/CCMP).

Bad (Hạn chế): Chỉ ra các lỗ hổng nghiêm trọng như sử dụng giao thức cũ (Legacy Mixed Mode), phương thức xác thực cá nhân (Personal PSK) có nguy cơ bị tấn công

Brute-force, và việc thiếu tính năng bảo vệ khung quản lý (Missing MFP) khiến mạng dễ bị tấn công ngắt kết nối (De-authentication).

Nút **Report** ở góc trên bên phải cho phép trích xuất toàn bộ dữ liệu phân tích ra một định dạng tài liệu chuẩn. Chức năng này phục vụ mục đích lưu trữ kết quả kiểm thử và cung cấp thông tin cho các giai đoạn khắc phục lỗ hổng.



Hình 3.8. Điểm đánh giá bảo mật

Thuật toán hoạt động dựa trên phương pháp khấu trừ điểm. Hệ thống thiết lập một mức điểm cơ sở (Base score là 80) đại diện cho cấu hình mạng tiêu chuẩn. Từ mức điểm này, các yếu tố rủi ro phát hiện được trong quá trình phân tích sẽ bị trừ/cộng điểm trực tiếp theo các trọng số đã được thiết lập sẵn.

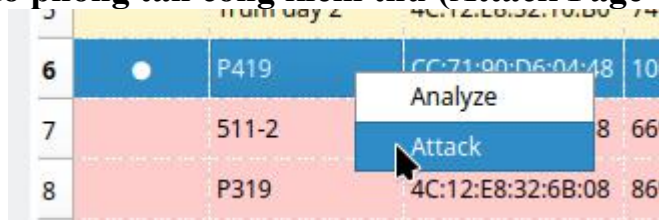


Hình 3.9. Các giải pháp gợi ý cho các cấu hình yếu

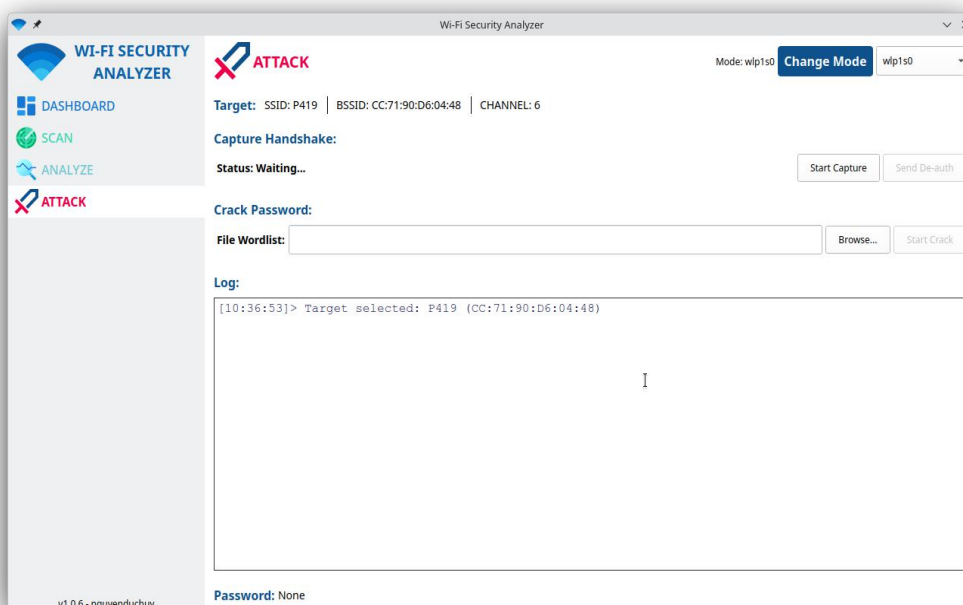
Bên cạnh việc nhận diện các nguy cơ bảo mật, hệ thống còn được thiết kế để cung cấp các giải pháp khắc phục cụ thể cho từng lỗi được phát hiện. Tại khu vực thống kê các điểm yếu (Bad), hệ thống tích hợp các biểu tượng trợ giúp (icon dấu hỏi màu xanh) bên cạnh mỗi dòng rủi ro.

Khi tương tác vào các biểu tượng này, một cửa sổ thông tin (Solution) sẽ xuất hiện, đưa ra các hướng dẫn kỹ thuật nhằm tối ưu hóa cấu hình mạng.

3.2.4. Phân hệ Mô phỏng tấn công kiểm thử (Attack Page - Deauth & Crack)



Hình 3.10. Chọn wifi để kiểm thử độ mạnh mật khẩu

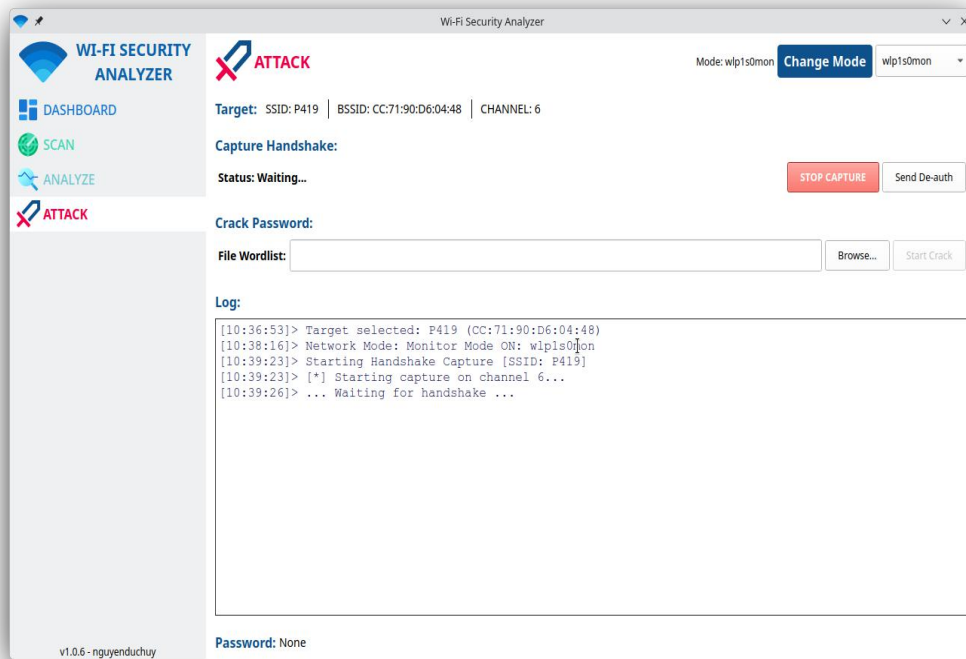


Hình 3.11. Giao diện Attack

Giao diện module Attack được thiết kế để thực hiện bài kiểm thử mật khẩu của wifi có đảm bảo an toàn không.



Hình 3.12. Nút chuyển đổi sang chế độ Monitor

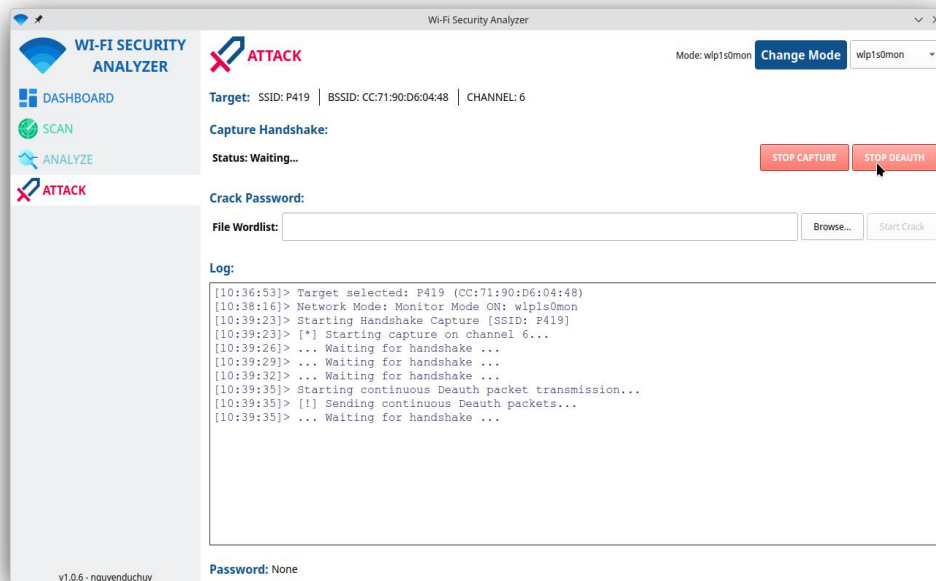


Hình 3.13. Chế độ thu thập gói tin

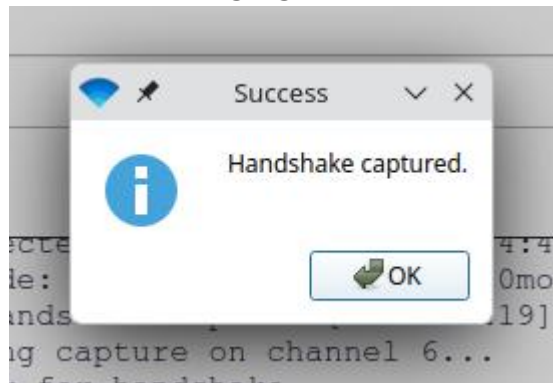
Chuyển đổi chế độ card mạng: Trước khi tiến hành thu thập, giao diện mạng được chuyển từ chế độ thông thường sang Monitor Mode (thể hiện qua tên interface wlp1s0mon). Chế độ này cho phép card mạng thu nhận toàn bộ các gói tin lưu thông trong không trung mà không cần thiết lập kết nối chính thức với điểm truy cập.

Kích hoạt tiến trình Capture: Khi lệnh bắt đầu được thực thi, hệ thống sẽ cố định việc lắng nghe tín hiệu trên kênh truyền cụ thể của mục tiêu (Channel 6). Trạng thái hệ thống chuyển sang "Waiting...", cho thấy tiến trình đang tích cực quét và lọc các gói tin EAPOL (4-way handshake) phát sinh khi có một thiết bị kết nối vào mạng P419.

Trong suốt quá trình này, nút chức năng được chuyển trạng thái thành Stop Capture (màu đỏ) để cho phép dừng tiến trình bất cứ lúc nào. Đồng thời, tính năng Send De-auth sẵn sàng được sử dụng để chủ động ngắt kết nối các thiết bị khách, buộc chúng phải tái kết nối và tạo ra gói tin bắt tay mới, từ đó rút ngắn thời gian chờ đợi của hệ thống.

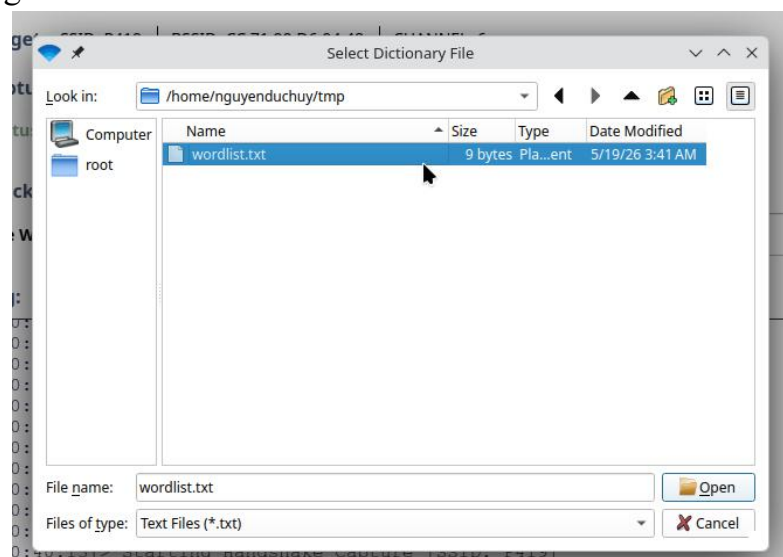


Hình 3.14. Chế độ gửi gói tin Deauthentication

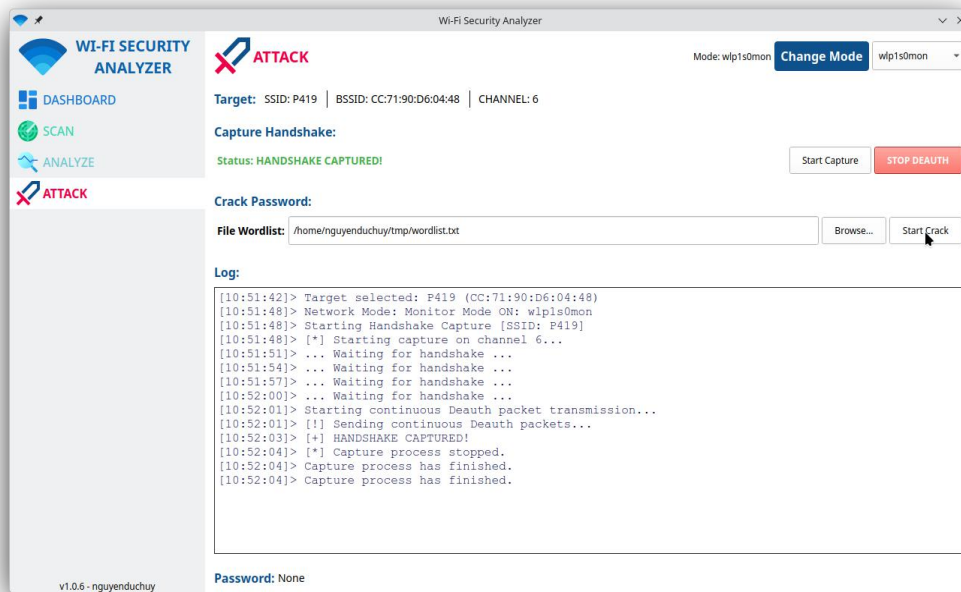


Hình 3.15. Bắt gói tin Handshake thành công

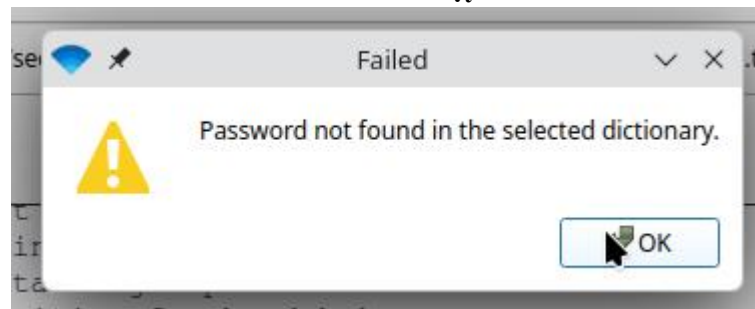
Nếu bắt thành công hệ thống phản hồi thông qua một hộp thoại thông báo (Success Dialog). Thông báo "Handshake captured" xác nhận rằng các gói tin quan trọng trong quy trình bắt tay 4 bước (4-way handshake) đã được bắt và trích xuất thành công từ lưu lượng mạng.



Hình 3.16. Chọn wordlist cho quá trình kiểm thử

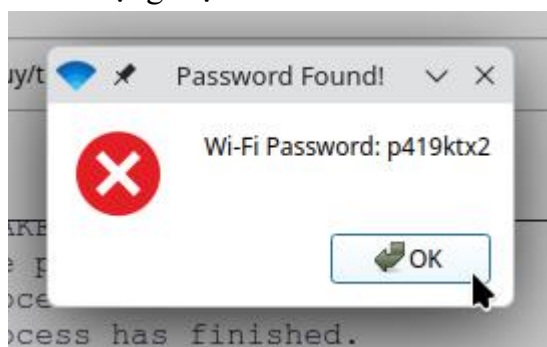


Hình 3.17. Bắt đầu chạy kiểm thử



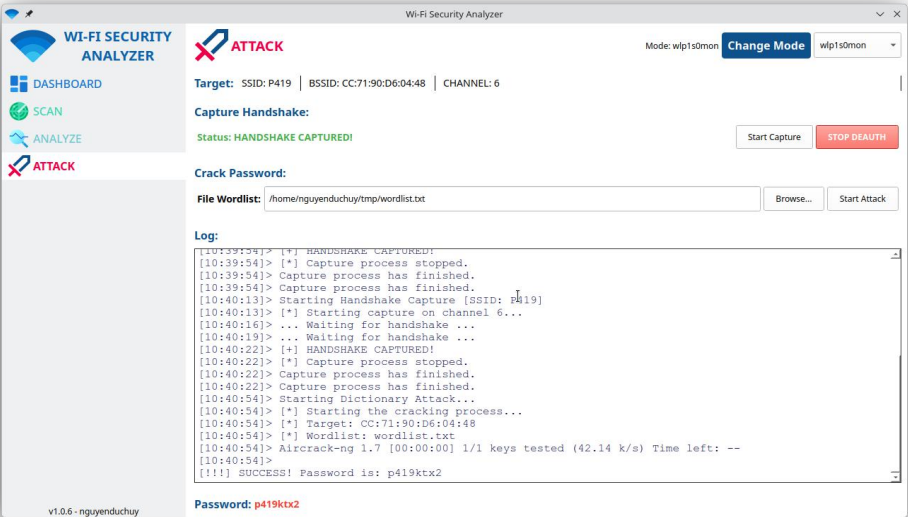
Hình 3.18. Trường hợp không tìm thấy mật khẩu

Thông báo "Password not found in the selected dictionary" xuất hiện khi tiến trình đối soát tệp từ điển (Wordlist) với gói tin Handshake đã hoàn tất mà không tìm thấy chuỗi ký tự khớp với mật khẩu của mạng mục tiêu.



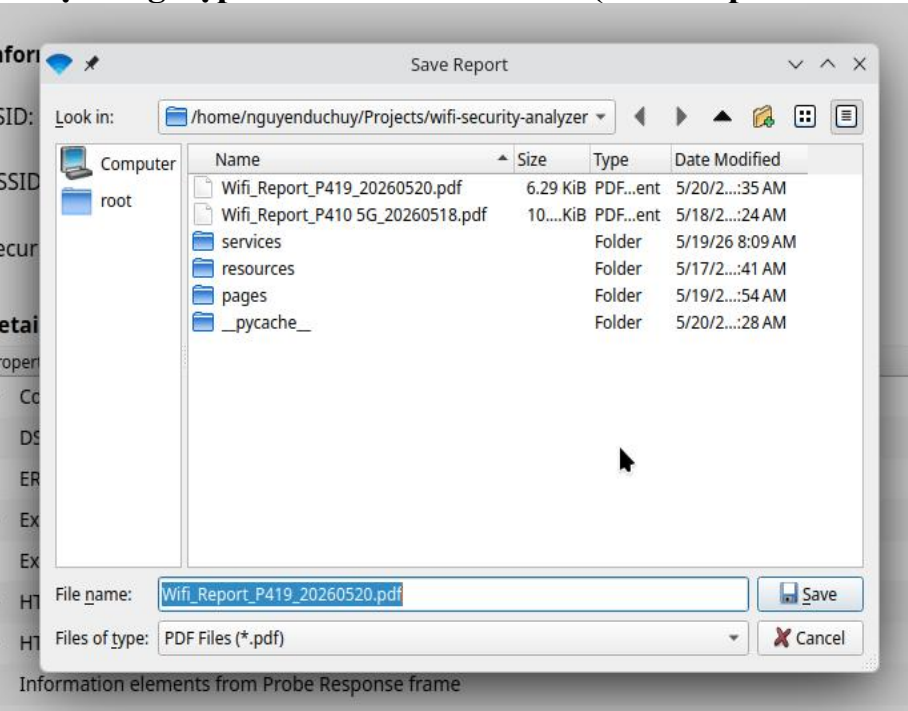
Hình 3.19. Trường hợp tìm thấy mật khẩu

Hộp thoại thông báo "Password Found!" xuất hiện ngay khi thuật toán đối soát tìm thấy sự trùng khớp hoàn toàn giữa một chuỗi ký tự trong tệp từ điển và gói tin Handshake đã thu thập trước đó.



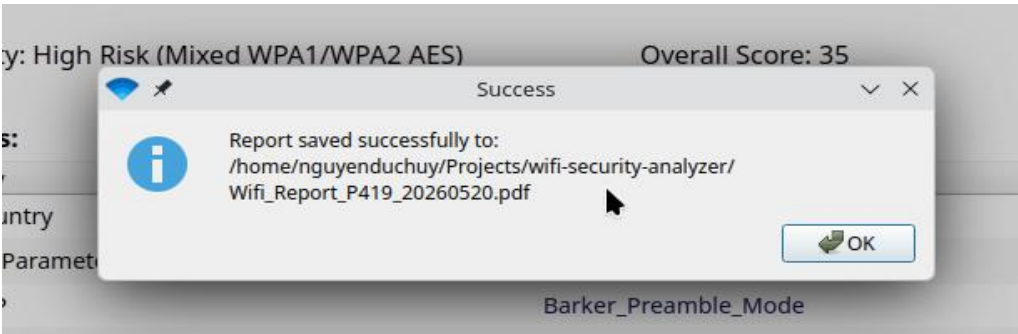
Hình 3.20. Kết quả quá trình kiểm thử

3.2.5. Phân hệ Tổng hợp và trích xuất báo cáo (PDF Report Generator)



Hình 3.21. Giao diện xuất báo cáo file PDF

Ở trang Analyze, nhấn vào nút Report để xuất báo cáo, xuất hiện hộp thoại chọn vị trí lưu



Hình 3.22. Thông báo xuất file thành công

Wi-Fi SECURITY ANALYSIS REPORT

Report ID: A811D287 | Date: 20/35/2026, 10:35

SSID: P419 BSSID: CC:71:90:D6:04:48 Security: High Risk (Mixed WPA1/WPA2 AES) Signal: -43.00 dBm Channel: channel 6 (2.4GHz)	SECURITY SCORE 35 out of 100
---	--

✓ Positive Security Features

- Strong AES/CCMP encryption: The current industry standard for data privacy.

■ Identified Risks & Mitigations

RISK: Legacy Mixed Mode: Supports outdated WPA1 protocols.

Action: Update router configuration to 'WPA2-AES Only'. Supporting WPA1 makes your network vulnerable to older exploits.

RISK: Personal PSK: Vulnerable to offline dictionary/brute-force attacks.

Action: Use a complex password (12+ characters, mixed cases, numbers, symbols) and change it periodically.

RISK: Missing MFP: Vulnerable to de-authentication (disconnection) attacks.

Action: Enable 'Management Frame Protection' (802.11w) in security settings to prevent attackers from

Hình 3.23. Kết quả file báo cáo

3.3. Đánh giá kết quả đạt được

3.3.1. Ưu điểm của giải pháp

Tự động hóa luồng kiểm thử: Tích hợp liền mạch các công cụ dòng lệnh (CLI). Hệ thống tự động chuyển tiếp từ rà quét, giám sát bắt gói tin đến bẻ khóa ngoại tuyến mà không cần người dùng can thiệp thủ công.

Động cơ phân tích rủi ro thông minh: Bộ máy chấm điểm (Scoring Engine) bóc tách chi tiết cấu hình mạng (chuẩn mã hóa, WPS, MFP, TKIP) để đưa ra xếp loại bảo mật và cảnh báo trực quan.

Trải nghiệm người dùng (UX) tối ưu: Việc áp dụng kiến trúc đa luồng giúp tách biệt tiến trình mạng nặng khỏi giao diện chính, đảm bảo phần mềm luôn mượt mà và phản hồi log theo thời gian thực.

Báo cáo chuyên nghiệp: Khả năng tự động tổng hợp kết quả phân tích và kết xuất thành tài liệu PDF (qua thư viện ReportLab) kèm theo các đề xuất khắc phục rủi ro.

3.3.2. Các mặt hạn chế còn tồn đọng

Phụ thuộc phần cứng chuyên dụng: Các phân hệ Tấn công bắt buộc người dùng phải trang bị card mạng Wi-Fi (thường là USB rời) có hỗ trợ chế độ Monitor Mode và Packet Injection.

Giới hạn của tấn công từ điển: Tỷ lệ bẻ khóa thành công phụ thuộc hoàn toàn vào chất lượng của tệp từ điển (Wordlist), không hiệu quả đối với các mật khẩu phức tạp, sinh ngẫu nhiên.

Chưa hỗ trợ tấn công WPA3: Hệ thống hiện chỉ có khả năng nhận diện và đánh giá WPA3, nhưng chưa hỗ trợ các kỹ thuật bẻ khóa cơ chế xác thực SAE hay tấn công hạ cấp (Downgrade Attack) về WPA2.

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

1. KẾT LUẬN

Mạng không dây Wi-Fi đã trở thành hạ tầng thiết yếu trong cả môi trường doanh nghiệp lẫn hộ gia đình, song song với đó là sự gia tăng không ngừng của các nguy cơ bảo mật. Đồ án đã hoàn thành xuất sắc mục tiêu đặt ra: nghiên cứu, thiết kế và xây dựng thành công công cụ Wi-Fi Security Analyzer – một giải pháp hỗ trợ kiểm thử xâm nhập và đánh giá an toàn mạng toàn diện trên nền tảng Linux.

Về mặt lý thuyết: Củng cố và hệ thống hóa các kiến thức chuyên sâu về giao thức mạng 802.11, cơ chế xác thực/mã hóa (từ WEP, WPA2 đến WPA3), cũng như nguyên lý hoạt động của các hình thức tấn công phổ biến (Deauthentication, 4-Way Handshake Capture, Brute-force/Dictionary).

Về mặt kỹ thuật và thực tiễn: Xây dựng thành công một giao diện đồ họa (GUI) trực quan bằng thư viện PySide6, giúp trừu tượng hóa sự phức tạp của các công cụ dòng lệnh (CLI) kinh điển như iw và bộ aircrack-ng.

2. HƯỚNG PHÁT TRIỂN

Phát triển tính năng nhận diện trạm phát sóng giả mạo (Rogue AP / Evil Twin Detection): Bên cạnh các module mô phỏng tấn công, định hướng nâng cấp hệ thống thành một giải pháp phòng thủ chủ động là vô cùng cần thiết. Trong tương lai, phần mềm cần được tích hợp thêm thuật toán phân tích điểm bất thường (Anomaly Detection) để phát hiện các mạng Wi-Fi giả mạo (Evil Twin) hoặc trạm phát sóng trái phép (Rogue AP). Bằng cách liên tục giám sát và đối chiếu các trường dữ liệu tĩnh của Access Point hợp lệ (như OUI của nhà sản xuất, biểu đồ cường độ tín hiệu vật lý, các trường thông tin trong Beacon Frame và Probe Response), hệ thống có thể lập tức phát ra cảnh báo khi xuất hiện một trạm phát sóng giả mạo cố tình sao chép SSID để đánh cắp thông tin người dùng, qua đó bảo vệ an toàn cho cả thiết bị kiểm thử lẫn hạ tầng mạng nội bộ.

Trong tương lai, chuẩn WPA3 sẽ trở thành mặc định. Hệ thống cần nghiên cứu tích hợp các module tấn công hạ cấp giao thức (Downgrade Attacks) ép mạng WPA3 Mixed về WPA2, hoặc các công cụ chuyên dụng để phân tích rủi ro trên cơ chế xác thực SAE.

Thay vì chỉ tập trung vào tấn công (Offensive), hệ thống có thể bổ sung module lắng nghe thụ động để phát hiện và cảnh báo theo thời gian thực nếu chính mạng của người dùng đang bị tấn công (ví dụ: cảnh báo khi có quá nhiều gói tin Deauth xuất hiện trong mạng).

TÀI LIỆU THAM KHẢO

- [1] Jim Geier, “*Designing and Deploying 802.11 Wireless Networks: A Practical Guide to Implementing 802.11n and 802.11ac Wireless Networks, 2nd Edition*”, Cisco Press, 2015.
- [2] Matthew S. Gast, “*802.11 Wireless Networks: The Definitive Guide, 2nd Edition*”, O'Reilly Media, 2005.
- [3] Cameron Buchanan, Vivek Ramachandran, “*Kali Linux Wireless Penetration Testing Cookbook*”, Packt Publishing, 2017.
- [4] Justin Seitz, Tim Arnold, “*Black Hat Python: Python Programming for Hackers and Pentesters*”, 2nd Edition, No Starch Press, 2021.